



POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN ISO/IEC 27001

PearTrees Medical Services

Descripción breve

Documento elaborado como parte de un caso práctico de GRC.
PearTrees Medical Services es una organización ficticia utilizada para fines de análisis y
demostración.

Miguel Perales Rubio
Migperales30@gmail.com

CONTROL DEL DOCUMENTO	
Campo	Información
Nombre del documento	Política de seguridad de la Información
Código	PSI-001
Versión	1.0
Propietario	Responsable de Seguridad de la Información
Aprobador	Dirección
Clasificación	Uso interno
Fecha de emisión	Agosto 2026
Fecha de revisión	Agosto 2027
Estado	Aprobado
Norma de referencia	ISO/IEC 27001:2022

HISTORIAL DE VERSIONES	
Versión	1.0
Fecha	Agosto 2026
Descripción	Emisión inicial
Responsable	Responsable de Seguridad la Información

AVISO DE PROPIEDAD INTELECTUAL Y DERECHOS DE USO

© 2026 Miguel Perales. Todos los derechos reservados.

Este documento ha sido elaborado como parte de un portfolio profesional orientado a la gestión de riesgos, gobierno, riesgo y cumplimiento (GRC) y seguridad de la información.

La organización *PearTrees Medical Services* utilizada en este documento es ficticia y se emplea exclusivamente con fines académicos, formativos y demostrativos. Los escenarios, activos, procesos, responsables, registros y demás elementos asociados a dicha organización no representan información real de una entidad existente.

El contenido del documento, incluyendo su estructura, redacción, análisis, modelos y elementos desarrollados específicamente para este portfolio, es obra de su autor.

Se permite la consulta y visualización del documento con fines personales, educativos o profesionales, siempre que se mantenga la atribución correspondiente.

No se autoriza, sin consentimiento previo del autor:

- La reproducción íntegra del documento con finalidad comercial.
- La redistribución del documento como obra propia.
- La modificación y publicación del documento atribuyéndolo a terceros.
- La utilización del contenido para elaborar productos o servicios comerciales basados sustancialmente en este trabajo.

Las referencias a normas, estándares, metodologías o marcos profesionales pertenecen a sus respectivos propietarios y se utilizan únicamente como referencias dentro del trabajo.

La inclusión de este documento en el portfolio no implica certificación, acreditación ni conformidad formal con ninguna norma o estándar. El documento constituye un ejercicio profesional simulado y no sustituye una auditoría, evaluación de conformidad o certificación realizada por un organismo competente.

Contenido

1. Propósito	8
2. Objetivos	9
2.1. Protección de la información.....	9
2.2. Gestión de riesgos	9
2.3. Prevención y gestión de incidentes	10
2.4. Protección frente a vulnerabilidades.....	10
2.5. Continuidad y recuperación	10
2.6. Concienciación y formación.....	10
2.7. Cumplimiento	11
2.8. Mejora continua	11
3. Alcance	11
3.1. Ubicaciones.....	11
3.2. Personas.....	12
3.3. Información	12
3.4. Sistemas y activos tecnológicos	13
3.5. Procesos	13
3.6. Terceros y servicios externalizados	14
3.7. Exclusiones	14
3.8. Revisión del alcance.....	14
4. Contexto de la organización	15
4.1. Descripción de la organización.....	15
4.2. Necesidad de protección de la información	15
4.3. Entorno interno	16
4.4. Entorno externo.....	16
4.5. Partes interesadas.....	17
4.6. Enfoque de gestión	17
5. Principios de Seguridad de la Información	18
5.1. Gestión basada en riesgos	18
5.2. Confidencialidad, integridad y disponibilidad	18
5.3. Mínimo privilegio	18

5.4. Necesidad de conocer	19
5.5. Defensa en profundidad.....	19
5.6. Segregación de funciones	19
5.7. Seguridad desde el diseño	19
5.8. Responsabilidad individual	19
5.9. Cumplimiento	20
5.10. Proporcionalidad	20
5.11. Mejora continua	20
6. Compromiso de la Dirección	20
6.1. Integración de la seguridad en la organización.....	20
6.2. Provisión de recursos.....	21
6.3. Establecimiento de objetivos	21
6.4. Gestión de riesgos	21
6.5. Cumplimiento de requisitos	21
6.6. Asignación de responsabilidades	21
6.7. Cultura y concienciación	22
6.8. Mejora continua	22
6.9. Apoyo al SGSI.....	22
6.10. Declaración de compromiso	22
7. Objetivos de Seguridad de la Información.....	23
7.1. Objetivos establecidos	23
7.2. Seguimiento de los objetivos.....	24
7.3. Revisión de los objetivos	24
7.4. Evidencias	25
8. Roles, responsabilidades y autoridades	25
8.1. Dirección	26
8.2. Responsable de Seguridad de la Información / Responsable del SGSI.....	26
8.3. Área de Tecnologías de la Información	27
8.4. Responsables de procesos y activos.....	27
8.5. Recursos Humanos	28
8.6. Usuarios	28

8.7. Proveedores y terceros	29
8.8. Independencia y segregación de funciones	29
8.9. Comunicación de responsabilidades.....	29
8.10. Matriz de responsabilidades.....	29
9. Compromisos y directrices de seguridad.....	30
9.1. Gestión de activos	30
9.2. Clasificación y protección de la información	30
9.3. Control de acceso	30
9.4. Gestión de credenciales	31
9.5. Seguridad de sistemas y redes	31
9.6. Gestión de vulnerabilidades.....	32
9.7. Gestión de cambios.....	32
9.8. Desarrollo y adquisición de sistemas.....	32
9.9. Gestión de incidentes de seguridad	33
9.10. Continuidad y recuperación	33
9.11. Copias de seguridad	34
9.12. Seguridad física.....	34
9.13. Teletrabajo y dispositivos fuera de las instalaciones.....	34
9.14. Seguridad de proveedores y terceros	35
9.15. Formación y concienciación.....	35
9.16. Protección de datos e información sensible	36
9.17. Registros y monitorización	36
9.18. Uso aceptable de los recursos.....	36
9.19. Eliminación y destrucción segura	37
9.20. Cumplimiento y revisión de controles	37
10. Cumplimiento de requisitos aplicables	37
10.1. Requisitos legales y reglamentarios	37
10.2. Protección de datos personales.....	38
10.3. Requisitos contractuales	38
10.4. Requisitos de las partes interesadas.....	39
10.5. ISO/IEC 27001	39

10.6. Estándares y buenas prácticas	39
10.7. Evaluación del cumplimiento	40
10.8. Gestión de incumplimientos	40
10.9. Registro de requisitos aplicables	41
11. Gestión de excepciones	41
11.1. Solicitud de una excepción	42
11.2. Evaluación del riesgo	42
11.3. Medidas compensatorias	43
11.4. Aprobación	43
11.5. Duración y revisión	43
11.6. Registro de excepciones	43
11.7. Revisión de excepciones	44
12. Comunicación y aceptación de la política	44
12.1. Comunicación interna	44
12.2. Conocimiento y aceptación	45
12.3. Comunicación a terceros	45
12.4. Disponibilidad de la política	46
12.5. Comunicación externa	46
12.6. Comunicación de cambios	46
12.7. Evidencias de comunicación	46
13. Revisión y mejora continua	47
13.1. Revisión periódica	47
13.2. Revisión extraordinaria	48
13.3. Evaluación de la eficacia	48
13.4. Gestión de modificaciones	49
13.5. Acciones correctivas y de mejora	49
13.7. Comunicación de las modificaciones	50
13.8. Evidencias	50
14. Estructura documental y políticas específicas de seguridad	51
14.1. Estructura documental	51
Nivel 1 — Política general	51

Nivel 2 — Políticas y normas específicas	52
Nivel 3 — Procedimientos	52
Nivel 4 — Registros y evidencias	53
14.2. Relación entre documentos	53
14.3. Gestión documental	54
14.4. Coherencia entre políticas	54
14.6. Desarrollo progresivo del SGSI.....	55
15. Aprobación, vigencia y control de versiones.....	55
15.1. Aprobación	55
15.2. Entrada en vigor.....	56
15.3. Vigencia.....	56
15.4. Control de versiones	56
15.5. Distribución y versiones obsoletas.....	57
15.6. Propiedad del documento	57
ANEXO A. DOCUMENTOS RELACIONADOS.....	58
A.1. Documentos de gobierno y gestión.....	58
A.2. Documentos de gestión de riesgos	58
A.3. Políticas y normas específicas de seguridad	59
A.4. Procedimientos.....	60
A.5. Registros y evidencias	61
A.6. Relación documental	62
A.7. Estado de los documentos	62
ANEXO B. MATRIZ DE TRAZABILIDAD CON ISO/IEC 27001:2022.....	63
B.1. Trazabilidad de los requisitos de las cláusulas 4 a 10	63
B.2. Trazabilidad de los controles relevantes del Anexo A.....	66
B.3. Interpretación de la matriz	71
B.4. Relación con la Declaración de Aplicabilidad	71
B.5. Revisión de la trazabilidad	72
ANEXO C. GLOSARIO Y DEFINICIONES	72

1. Propósito

El presente documento establece el marco general de actuación de *PearTrees Medical Services* para la protección de la información y de los activos asociados a su tratamiento, almacenamiento, transmisión y utilización.

La política tiene como finalidad establecer los principios, compromisos y directrices que deben regir la gestión de la seguridad de la información en la organización, proporcionando una base común para la identificación, evaluación y tratamiento de los riesgos que puedan afectar a la **confidencialidad, integridad y disponibilidad** de la información.

PearTrees Medical Services reconoce la información como un activo esencial para el desarrollo de sus actividades y asume que su protección requiere la participación coordinada de la Dirección, empleados, colaboradores y terceros que tengan acceso a los recursos de información de la organización.

Esta política constituye el marco de referencia para el establecimiento, implantación, mantenimiento y mejora continua del Sistema de Gestión de Seguridad de la Información (SGSI) de *PearTrees Medical Services*, de acuerdo con los principios establecidos en la norma ISO/IEC 27001:2022.

Asimismo, esta política establece el compromiso de la organización con:

- La protección de la información frente a accesos, usos, modificaciones, divulgaciones o destrucciones no autorizadas.
- La gestión de los riesgos de seguridad de la información de acuerdo con un enfoque basado en riesgos.
- El cumplimiento de los requisitos legales, reglamentarios, contractuales y otros requisitos aplicables a la organización.
- La asignación de responsabilidades en materia de seguridad de la información.
- La concienciación y formación de las personas que intervienen en el tratamiento de la información.
- La prevención, detección, respuesta y recuperación ante incidentes de seguridad de la información.
- La mejora continua de la eficacia del SGSI.

La presente política constituye el nivel superior de la documentación interna de seguridad de la información y proporciona el marco para el desarrollo de políticas,

procedimientos, normas y controles específicos que permitan gestionar los riesgos identificados y alcanzar los objetivos de seguridad establecidos por la organización.

2. Objetivos

La presente política establece el marco de referencia para la definición de los objetivos de seguridad de la información de *PearTrees Medical Services*, que deberán estar alineados con la estrategia de la organización, el contexto del SGSI y los riesgos identificados.

Los objetivos de seguridad deberán contribuir a proteger la información y los activos asociados, reducir los riesgos hasta niveles aceptables para la organización y mejorar de forma continua la eficacia del Sistema de Gestión de Seguridad de la Información (SGSI).

Los objetivos se establecerán de manera que, cuando resulte aplicable, sean medibles, verificables y sujetos a seguimiento, definiendo para cada uno de ellos los indicadores, responsables, recursos, plazos y criterios de evaluación correspondientes.

Con carácter general, *PearTrees Medical Services* establece los siguientes objetivos de seguridad de la información:

2.1. Protección de la información

Garantizar la protección de la información frente a accesos, modificaciones, divulgaciones, pérdidas o destrucciones no autorizadas, preservando su:

- **Confidencialidad**, asegurando que la información únicamente sea accesible por personas, procesos o sistemas autorizados.
- **Integridad**, garantizando que la información se mantenga completa, exacta y protegida frente a modificaciones no autorizadas.
- **Disponibilidad**, asegurando que la información y los servicios necesarios para la actividad de la organización estén disponibles cuando sean requeridos.

2.2. Gestión de riesgos

Mantener un proceso sistemático de identificación, análisis, evaluación y tratamiento de los riesgos de seguridad de la información, de acuerdo con los criterios establecidos por la organización.

Los riesgos deberán mantenerse dentro de los niveles de aceptación definidos por *PearTrees Medical Services* y ser objeto de seguimiento periódico.

2.3. Prevención y gestión de incidentes

Mejorar la capacidad de la organización para prevenir, detectar, analizar, responder y recuperarse ante incidentes de seguridad de la información.

La organización realizará un seguimiento de indicadores relacionados con la gestión de incidentes, incluyendo, cuando resulte aplicable:

- Tiempo medio de detección (MTTD).
- Tiempo medio de respuesta y recuperación (MTTR).
- Número y severidad de incidentes registrados.
- Porcentaje de incidentes gestionados dentro de los plazos establecidos.
- Número de incidentes recurrentes.

2.4. Protección frente a vulnerabilidades

Reducir la exposición de los sistemas y activos tecnológicos frente a vulnerabilidades conocidas mediante procesos de identificación, evaluación, priorización y tratamiento.

Se establecerán criterios de prioridad y plazos de tratamiento en función de la criticidad de los activos y del nivel de riesgo asociado.

2.5. Continuidad y recuperación

Mejorar la capacidad de *PearTrees Medical Services* para mantener sus servicios esenciales y recuperar la información y los sistemas afectados por incidentes o situaciones disruptivas.

Para ello, se establecerán y revisarán mecanismos de respaldo, recuperación y continuidad adecuados a la criticidad de los servicios y de la información.

2.6. Concienciación y formación

Garantizar que las personas que desarrollan actividades para *PearTrees Medical Services* conozcan sus responsabilidades en materia de seguridad de la información y dispongan de la formación y concienciación necesaria para desempeñar sus funciones de forma segura.

La organización realizará actividades periódicas de formación y concienciación y realizará un seguimiento de su eficacia.

2.7. Cumplimiento

Identificar, mantener y cumplir los requisitos legales, reglamentarios, contractuales y otros requisitos aplicables relacionados con la seguridad de la información y la protección de los datos tratados por la organización.

2.8. Mejora continua

Mejorar continuamente la eficacia y adecuación del SGSI mediante el seguimiento de objetivos e indicadores, la revisión de riesgos, el análisis de incidentes, las auditorías, la identificación de no conformidades y la aplicación de acciones correctivas y de mejora.

Los objetivos de seguridad de la información serán revisados periódicamente por la organización y podrán modificarse cuando existan cambios relevantes en el contexto, los riesgos, las necesidades del negocio o los requisitos aplicables.

3. Alcance

La presente Política de Seguridad de la Información es de aplicación al Sistema de Gestión de Seguridad de la Información (SGSI) de *PearTrees Medical Services* y establece los principios y requisitos generales aplicables a la protección de la información y de los activos asociados a su tratamiento.

El alcance del SGSI comprende las actividades, procesos, personas, instalaciones, sistemas de información, redes, aplicaciones y servicios tecnológicos utilizados para desarrollar y soportar las actividades corporativas de *PearTrees Medical Services*.

3.1. Ubicaciones

El alcance comprende las tres ubicaciones operativas de *PearTrees Medical Services*:

- **Palma**, donde se encuentran las principales funciones corporativas y servicios de soporte.
- **Sóller**, correspondiente a una de las sedes operativas de la organización.
- **Manacor**, correspondiente a una de las sedes operativas de la organización.

Los requisitos establecidos en esta política serán aplicables a los activos de información y sistemas utilizados en cualquiera de estas ubicaciones cuando se encuentren dentro del alcance definido del SGSI.

3.2. Personas

La política es aplicable a todas las personas que desarrollen actividades para *PearTrees Medical Services* y que puedan acceder a información o recursos incluidos en el alcance del SGSI.

Esto incluye, entre otros:

- Empleados.
- Personal directivo.
- Personal temporal.
- Colaboradores.
- Personal externo con acceso autorizado.
- Proveedores y terceros que, en virtud de sus funciones, tengan acceso a información, sistemas o instalaciones de la organización.

El acceso a los recursos de información estará sujeto a las responsabilidades y condiciones de seguridad establecidas por la organización.

3.3. Información

El alcance comprende la información utilizada, generada, almacenada, procesada o transmitida en el desarrollo de las actividades de *PearTrees Medical Services*, independientemente de su formato o soporte.

Se incluyen, entre otros:

- Información corporativa y administrativa.
- Información financiera y contable.
- Información relativa a empleados y recursos humanos.
- Información de pacientes y usuarios.
- Información relacionada con la prestación de los servicios de la organización.
- Información técnica y operativa.
- Credenciales y datos de autenticación.
- Registros y evidencias de actividad.
- Documentación interna.

- Copias de seguridad.
- Información almacenada en sistemas y servicios tecnológicos.

La información será protegida de acuerdo con su clasificación, criticidad, requisitos legales y contractuales y nivel de riesgo asociado.

3.4. Sistemas y activos tecnológicos

El alcance comprende los activos tecnológicos que soportan los procesos y servicios incluidos en el SGSI, incluyendo, entre otros:

- Servidores y sistemas de almacenamiento.
- Equipos de usuario.
- Dispositivos corporativos.
- Infraestructura de red y comunicaciones.
- Sistemas operativos.
- Aplicaciones corporativas.
- Bases de datos.
- Sistemas de copia de seguridad.
- Servicios de correo electrónico y colaboración.
- Sistemas de autenticación y control de acceso.
- Herramientas de seguridad.
- Servicios tecnológicos proporcionados por terceros.

Los activos deberán estar identificados y contar con un responsable definido de acuerdo con los procesos establecidos por el SGSI.

3.5. Procesos

El SGSI contempla los procesos corporativos y tecnológicos que intervienen en la protección y disponibilidad de la información dentro del alcance definido.

Entre ellos se incluyen:

- Gestión y administración de sistemas de información.
- Gestión de usuarios y accesos.
- Gestión de activos.

- Gestión de vulnerabilidades y actualizaciones.
- Gestión de copias de seguridad.
- Gestión de incidentes de seguridad.
- Gestión de continuidad y recuperación.
- Gestión de proveedores tecnológicos.
- Formación y concienciación en seguridad.
- Gestión de riesgos de seguridad de la información.
- Supervisión y mejora del SGSI.

3.6. Terceros y servicios externalizados

Los proveedores y terceros que presten servicios o dispongan de acceso a información o activos incluidos en el alcance estarán sujetos a los requisitos de seguridad establecidos por *PearTrees Medical Services* en función del riesgo asociado.

Los servicios externalizados que soporten procesos o información incluidos en el alcance deberán ser considerados dentro de la gestión de riesgos del SGSI y estarán sujetos a los requisitos contractuales y de seguridad que resulten aplicables.

3.7. Exclusiones

Cualquier exclusión de actividades, procesos, sistemas, ubicaciones o activos respecto del alcance del SGSI deberá estar formalmente justificada, documentada y aprobada por la autoridad competente.

Las exclusiones no podrán utilizarse para evitar de forma injustificada la aplicación de requisitos de seguridad relevantes para los procesos, información o servicios incluidos en el alcance.

3.8. Revisión del alcance

El alcance del SGSI será revisado periódicamente y ante cambios significativos en la organización, sus procesos, tecnologías, ubicaciones, servicios, proveedores, requisitos aplicables o perfil de riesgo.

Cualquier modificación relevante del alcance deberá quedar documentada y ser comunicada a las partes interesadas correspondientes.

4. Contexto de la organización

4.1. Descripción de la organización

PearTrees Medical Services es una organización ficticia del sector sanitario utilizada como escenario de referencia para el diseño y aplicación de un Sistema de Gestión de Seguridad de la Información (SGSI).

La organización cuenta con aproximadamente 240 empleados y desarrolla sus actividades a través de tres ubicaciones operativas situadas en Palma, Sóller y Manacor.

La actividad de la organización depende de la disponibilidad y correcto funcionamiento de diferentes sistemas de información, infraestructuras tecnológicas y servicios de comunicaciones que permiten gestionar información corporativa y prestar sus servicios.

En el desarrollo de sus actividades, *PearTrees Medical Services* trata información de distinta naturaleza y criticidad, incluyendo información corporativa, administrativa, financiera, laboral, técnica y relacionada con pacientes y usuarios.

La dependencia de los sistemas de información, junto con la naturaleza de la información tratada, hace necesario establecer un marco sistemático para gestionar los riesgos de seguridad de la información y garantizar la protección de los activos esenciales para la organización.

4.2. Necesidad de protección de la información

La información constituye un activo esencial para *PearTrees Medical Services*. Una pérdida de confidencialidad, integridad o disponibilidad puede afectar a la continuidad de las operaciones, a la prestación de los servicios, al cumplimiento de obligaciones legales y contractuales y a la confianza de clientes, empleados y otras partes interesadas.

Entre las principales circunstancias que pueden afectar a la seguridad de la información se encuentran:

- Accesos no autorizados a sistemas o información.
- Pérdida o divulgación indebida de información.
- *Malware* y *ransomware*.
- Ataques de *phishing* e ingeniería social.
- Explotación de vulnerabilidades técnicas.

- Fallos de sistemas o infraestructuras.
- Errores humanos.
- Pérdida o indisponibilidad de activos tecnológicos.
- Incidentes relacionados con proveedores o servicios externalizados.
- Interrupciones que afecten a la continuidad de los servicios.

Por este motivo, la organización adopta un enfoque basado en la gestión de riesgos como fundamento para determinar las medidas de seguridad necesarias.

4.3. Entorno interno

El entorno interno de *PearTrees Medical Services* está compuesto por:

- Personal con diferentes funciones y niveles de acceso a la información.
- Procesos corporativos y operativos soportados por sistemas de información.
- Infraestructuras tecnológicas distribuidas entre diferentes ubicaciones.
- Sistemas y aplicaciones utilizados para el desarrollo de las actividades de la organización.
- Servicios tecnológicos internos y externalizados.
- Información con diferentes niveles de criticidad y requisitos de protección.

La organización establece responsabilidades relacionadas con la seguridad de la información y promueve la participación de las distintas áreas en la gestión y protección de los activos bajo su responsabilidad.

4.4. Entorno externo

Entre los factores externos relevantes para la seguridad de la información se consideran:

- Evolución de las amenazas y técnicas de ataque.
- Dependencia de proveedores tecnológicos.
- Cambios tecnológicos.
- Requisitos legales y reglamentarios.
- Obligaciones contractuales.
- Expectativas de clientes y otras partes interesadas.

- Evolución de las buenas prácticas y estándares de seguridad.
- Cambios en el entorno económico y operativo de la organización.

Estos factores deberán ser considerados en la identificación y evaluación de riesgos del SGSI.

4.5. Partes interesadas

Las partes interesadas relevantes para la seguridad de la información pueden incluir:

- Dirección de la organización.
- Empleados y colaboradores.
- Clientes y usuarios.
- Proveedores de servicios tecnológicos.
- Proveedores y terceros con acceso a información.
- Organismos reguladores y autoridades competentes.
- Aseguradoras u otras entidades que establezcan requisitos de seguridad.
- Otras organizaciones o entidades con las que *PearTrees Medical Services* mantenga relaciones contractuales.

Las necesidades y expectativas de las partes interesadas que sean relevantes para el SGSI serán identificadas, evaluadas y consideradas en la definición de los requisitos de seguridad de la información.

4.6. Enfoque de gestión

PearTrees Medical Services adopta un enfoque de mejora continua basado en el ciclo de planificación, implantación, evaluación y mejora del SGSI.

La organización utilizará la información obtenida mediante la evaluación de riesgos, la gestión de incidentes, las auditorías, el seguimiento de indicadores y las revisiones del SGSI para identificar oportunidades de mejora y adaptar las medidas de seguridad a la evolución del contexto y de las amenazas.

El contexto de la organización y las necesidades de las partes interesadas serán revisados periódicamente y cuando se produzcan cambios relevantes que puedan afectar al SGSI.

5. Principios de Seguridad de la Información

PearTrees Medical Services establece los siguientes principios como marco de referencia para la gestión de la seguridad de la información y para el diseño, implantación, operación y mejora del Sistema de Gestión de Seguridad de la Información (SGSI).

Estos principios deberán ser considerados en las decisiones relacionadas con los procesos, personas, tecnologías, información y servicios incluidos en el alcance del SGSI.

5.1. Gestión basada en riesgos

Las decisiones relacionadas con la seguridad de la información se basarán en la identificación, análisis y evaluación de los riesgos que puedan afectar a la organización.

Los recursos y medidas de seguridad deberán priorizarse teniendo en cuenta la probabilidad y el impacto potencial de los riesgos, así como la criticidad de los activos y procesos afectados.

5.2. Confidencialidad, integridad y disponibilidad

La protección de la información se fundamentará en el mantenimiento de sus tres propiedades esenciales:

- **Confidencialidad:** la información únicamente deberá estar disponible para las personas, procesos o sistemas autorizados.
- **Integridad:** la información deberá mantenerse completa, exacta y protegida frente a modificaciones no autorizadas.
- **Disponibilidad:** la información y los servicios necesarios deberán encontrarse disponibles cuando sean requeridos por los procesos autorizados.

5.3. Mínimo privilegio

Los usuarios, procesos y sistemas dispondrán únicamente de los privilegios necesarios para desarrollar sus funciones.

Los permisos deberán asignarse de acuerdo con las responsabilidades y necesidades de cada usuario y revisarse periódicamente para evitar privilegios innecesarios o excesivos.

5.4. Necesidad de conocer

El acceso a la información estará limitado a aquellas personas que necesiten disponer de ella para el desempeño de sus funciones.

El hecho de pertenecer a la organización no implicará automáticamente el derecho de acceso a toda la información disponible.

5.5. Defensa en profundidad

La protección de los activos de información se realizará mediante la combinación de diferentes medidas de seguridad organizativas, técnicas y físicas.

La organización evitará depender de una única medida de protección y establecerá mecanismos complementarios destinados a prevenir, detectar, responder y recuperarse ante incidentes.

5.6. Segregación de funciones

Cuando resulte necesario para reducir riesgos, las funciones incompatibles deberán ser distribuidas entre diferentes personas o roles.

Se prestará especial atención a aquellas actividades relacionadas con la administración de sistemas, gestión de privilegios, aprobación de accesos, gestión de cambios y operaciones críticas.

5.7. Seguridad desde el diseño

La seguridad de la información deberá considerarse desde las fases iniciales de diseño, adquisición, desarrollo, modificación o implantación de sistemas, procesos y servicios.

Los requisitos de seguridad deberán identificarse y evaluarse antes de la puesta en producción de aquellos sistemas o servicios que puedan afectar a la información incluida en el alcance del SGSI.

5.8. Responsabilidad individual

Cada persona será responsable de las acciones realizadas utilizando sus cuentas, credenciales o recursos asignados.

Las credenciales deberán mantenerse bajo control del usuario autorizado y no deberán compartirse con otras personas.

Los usuarios deberán comunicar cualquier situación que pueda comprometer la seguridad de la información de acuerdo con los procedimientos establecidos por la organización.

5.9. Cumplimiento

Las actividades de tratamiento y protección de la información deberán cumplir los requisitos legales, reglamentarios, contractuales y organizativos que resulten aplicables.

La organización identificará y mantendrá actualizados los requisitos relevantes para el SGSI.

5.10. Proporcionalidad

Las medidas de seguridad deberán ser proporcionales al riesgo que pretenden reducir, teniendo en cuenta la criticidad de los activos, el impacto potencial de los incidentes, los requisitos aplicables y las necesidades de la organización.

5.11. Mejora continua

La seguridad de la información deberá gestionarse como un proceso continuo.

PearTrees Medical Services utilizará los resultados de la evaluación de riesgos, incidentes, auditorías, revisiones, indicadores y acciones correctivas para identificar oportunidades de mejora y adaptar el SGSI a los cambios de la organización y de su entorno.

6. Compromiso de la Dirección

La Dirección de *PearTrees Medical Services* reconoce la seguridad de la información como un elemento esencial para el cumplimiento de los objetivos de la organización, la continuidad de sus actividades y la protección de la información y de los activos asociados.

La Dirección asume la responsabilidad de proporcionar el liderazgo necesario para el establecimiento, implantación, mantenimiento y mejora continua del Sistema de Gestión de Seguridad de la Información (SGSI), asegurando que la seguridad de la información forme parte de la gestión ordinaria de la organización.

Para ello, la Dirección se compromete a:

6.1. Integración de la seguridad en la organización

Integrar los requisitos de seguridad de la información en los procesos y actividades de *PearTrees Medical Services*, evitando que la seguridad sea considerada exclusivamente como una responsabilidad del área tecnológica.

Las decisiones relacionadas con procesos, sistemas, servicios y cambios relevantes deberán considerar los riesgos de seguridad de la información que puedan afectar a la organización.

6.2. Provisión de recursos

Proporcionar los recursos necesarios para el establecimiento, funcionamiento, mantenimiento y mejora del SGSI, incluyendo los recursos humanos, tecnológicos, económicos y organizativos que resulten adecuados en función de los riesgos y necesidades de la organización.

6.3. Establecimiento de objetivos

Asegurar que se establezcan objetivos de seguridad de la información coherentes con la estrategia y las necesidades de *PearTrees Medical Services* y con el contexto del SGSI.

Los objetivos deberán ser objeto de seguimiento y revisión para determinar su grado de cumplimiento y eficacia.

6.4. Gestión de riesgos

Promover un enfoque basado en riesgos para la toma de decisiones relacionadas con la seguridad de la información.

La Dirección deberá garantizar que los riesgos relevantes sean identificados, evaluados y tratados de acuerdo con los criterios establecidos por la organización y que los riesgos residuales sean aceptados por las autoridades correspondientes.

6.5. Cumplimiento de requisitos

Apoyar el cumplimiento de los requisitos legales, reglamentarios, contractuales y otros requisitos aplicables relacionados con la seguridad de la información.

La Dirección promoverá la identificación y evaluación periódica de dichos requisitos y proporcionará los recursos necesarios para su cumplimiento.

6.6. Asignación de responsabilidades

Asegurar que las responsabilidades y autoridades relacionadas con la seguridad de la información sean definidas, comunicadas y comprendidas dentro de la organización.

La Dirección garantizará que las funciones necesarias para el funcionamiento del SGSI dispongan de la autoridad y los recursos adecuados para desarrollar sus responsabilidades.

6.7. Cultura y concienciación

Promover una cultura organizativa orientada a la protección de la información y al cumplimiento de las responsabilidades de seguridad.

La Dirección apoyará las actividades de formación y concienciación necesarias para que empleados, colaboradores y terceros comprendan sus obligaciones en materia de seguridad de la información.

6.8. Mejora continua

Promover la mejora continua de la adecuación, eficacia y desempeño del SGSI mediante la revisión de sus resultados, el análisis de riesgos, los indicadores, las auditorías, los incidentes, las acciones correctivas y las oportunidades de mejora identificadas.

6.9. Apoyo al SGSI

La Dirección proporcionará el respaldo necesario al responsable del SGSI y a las personas que desempeñen funciones relacionadas con la seguridad de la información, facilitando la coordinación entre las diferentes áreas de la organización.

Asimismo, la Dirección revisará periódicamente el desempeño del SGSI y adoptará las decisiones necesarias para garantizar su adecuación a las necesidades de *PearTrees Medical Services*.

6.10. Declaración de compromiso

La Dirección de *PearTrees Medical Services* manifiesta mediante la aprobación de esta política su compromiso con la protección de la información, la gestión adecuada de los riesgos de seguridad, el cumplimiento de los requisitos aplicables y la mejora continua del Sistema de Gestión de Seguridad de la Información.

La aprobación de esta política representa el respaldo formal de la Dirección a los principios y objetivos establecidos en ella y constituye la base para el desarrollo de las políticas, procedimientos y controles específicos que formen parte del SGSI.

7. Objetivos de Seguridad de la Información

PearTrees Medical Services establecerá objetivos de seguridad de la información coherentes con la presente política, con los objetivos estratégicos de la organización, con los riesgos identificados y con los requisitos aplicables al Sistema de Gestión de Seguridad de la Información (SGSI).

Los objetivos deberán ser objeto de seguimiento y revisión periódica y, cuando resulte aplicable, deberán disponer de indicadores que permitan evaluar su grado de cumplimiento y eficacia.

Para cada objetivo se determinarán las responsabilidades, recursos, plazos, indicadores y criterios de evaluación necesarios para su seguimiento.

7.1. Objetivos establecidos

Id	Objetivo	Indicador	Meta inicial	Responsable	Frecuencia
01	Mejora de la capacidad de detección de incidentes	MTTD	<24h	Responsable de seguridad	Mensual
02	Mejora de la capacidad de respuesta ante incidentes	MTTR	<72h	Seguridad/IT	Mensual
03	Reducción de la exposición ante vulnerabilidades críticas	% de vulnerabilidades críticas corregidas dentro del plazo establecido	>95%	Responsable de IT	Mensual
04	Mejorar la concienciación de los usuarios del sistema	% de empleados formados en materia de seguridad	>95%	RRHH/Seguridad	Trimestral
05	Garantizar la disponibilidad de las copias de seguridad	% de trabajos de backup realizados correctamente	>98%	IT	Mensual
06	Verificar la capacidad de recuperación	% de pruebas de restauración satisfactorias	>95%	IT	Trimestral

07	Mantener actualizado el inventario de activos	% de activos inventariados y asignados a un responsable	>98%	Responsable de activos/IT	Trimestral
08	Mejora de la gestión de accesos	% de revisiones de permisos realizadas en el plazo establecido	100%	IT/Responsable de seguridad	Trimestral
09	Garantizar el tratamiento adecuado de los incidentes	% de incidentes gestionados según procedimiento establecido	>95%	Responsable de seguridad	Mensual
10	Mantener el control sobre los riesgos de seguridad	% de riesgos con tratamiento o con aceptación	100%	Responsable de seguridad/dirección	Trimestral

7.2. Seguimiento de los objetivos

El seguimiento de los objetivos se realizará mediante los indicadores definidos para cada uno de ellos.

Los resultados serán registrados y analizados por los responsables correspondientes, identificando desviaciones respecto de las metas establecidas y determinando las acciones necesarias cuando se produzcan incumplimientos.

Cuando un objetivo no alcance el nivel establecido, se deberá analizar la causa de la desviación y, cuando resulte necesario, establecer acciones correctivas o de mejora.

Los resultados de los indicadores serán utilizados como información de entrada para la revisión del SGSI por parte de la Dirección.

7.3. Revisión de los objetivos

Los objetivos de seguridad serán revisados periódicamente y podrán ser modificados cuando se produzcan cambios significativos en:

- El contexto de la organización.
- Los riesgos de seguridad de la información.
- Los procesos o servicios.

- Las tecnologías utilizadas.
- Las amenazas relevantes.
- Los requisitos legales, reglamentarios o contractuales.
- Las necesidades y expectativas de las partes interesadas.
- El desempeño del SGSI.

Las modificaciones deberán quedar documentadas y contar con la aprobación de las responsabilidades correspondientes.

7.4. Evidencias

El seguimiento de los objetivos deberá generar información documentada que permita demostrar su evolución y grado de cumplimiento.

Entre las evidencias podrán incluirse:

- Informes periódicos de indicadores.
- Registros de incidentes.
- Informes de vulnerabilidades.
- Registros de formación y concienciación.
- Informes de copias de seguridad.
- Resultados de pruebas de restauración.
- Inventarios de activos.
- Registros de revisión de accesos.
- Registros de riesgos.
- Informes de seguimiento del SGSI.

Los resultados obtenidos podrán utilizarse como evidencia durante actividades de auditoría, revisión por la Dirección y procesos de mejora continua.

8. Roles, responsabilidades y autoridades

PearTrees Medical Services establecerá y mantendrá definidas las funciones, responsabilidades y autoridades necesarias para garantizar el funcionamiento eficaz del Sistema de Gestión de Seguridad de la Información (SGSI).

Las responsabilidades deberán estar claramente asignadas, comunicadas y comprendidas por las personas que desempeñen las funciones correspondientes.

La seguridad de la información constituye una responsabilidad compartida dentro de la organización. No obstante, determinadas funciones dispondrán de responsabilidades específicas para garantizar la adecuada dirección, coordinación, implantación, supervisión y mejora del SGSI.

8.1. Dirección

La Dirección de PearTrees Medical Services será responsable de proporcionar liderazgo y apoyo al SGSI.

Entre sus principales responsabilidades se encuentran:

- Aprobar la Política de Seguridad de la Información y sus modificaciones.
- Aprobar los objetivos de seguridad de la información.
- Proporcionar los recursos necesarios para el funcionamiento del SGSI.
- Determinar y aceptar los riesgos residuales dentro de los niveles de autoridad establecidos.
- Revisar periódicamente el desempeño y eficacia del SGSI.
- Promover una cultura de seguridad de la información.
- Garantizar que las responsabilidades y autoridades relacionadas con el SGSI estén definidas.
- Adoptar las decisiones necesarias para asegurar la mejora continua del SGSI.

8.2. Responsable de Seguridad de la Información / Responsable del SGSI

El Responsable de Seguridad de la Información será la figura encargada de coordinar y supervisar el funcionamiento del SGSI.

Entre sus responsabilidades se incluyen:

- Coordinar el mantenimiento y mejora del SGSI.
- Supervisar la aplicación de la Política de Seguridad de la Información.
- Coordinar la identificación, análisis y tratamiento de riesgos.
- Proponer objetivos e indicadores de seguridad.

- Supervisar el cumplimiento de los requisitos de seguridad establecidos.
- Coordinar la gestión de incidentes de seguridad.
- Informar periódicamente a la Dirección sobre el desempeño del SGSI.
- Coordinar las actividades de auditoría y revisión relacionadas con el SGSI.
- Promover actividades de formación y concienciación.
- Proponer acciones correctivas y oportunidades de mejora.
- Mantener la documentación del SGSI que corresponda a su función.

El Responsable de Seguridad deberá disponer de la autoridad y los recursos necesarios para desarrollar sus funciones y deberá mantener una comunicación adecuada con la Dirección y las diferentes áreas de la organización.

8.3. Área de Tecnologías de la Información

El área de Tecnologías de la Información será responsable de implementar y mantener las medidas técnicas y operativas necesarias para proteger los sistemas y servicios incluidos en el alcance del SGSI.

Entre sus responsabilidades se incluyen:

- Administrar los sistemas e infraestructuras tecnológicas.
- Aplicar las medidas de seguridad aprobadas.
- Gestionar actualizaciones y vulnerabilidades.
- Gestionar las cuentas y permisos de acuerdo con las directrices establecidas.
- Mantener los mecanismos de copia de seguridad y recuperación.
- Supervisar la disponibilidad y funcionamiento de los sistemas.
- Participar en la prevención, detección y respuesta ante incidentes.
- Mantener registros técnicos y evidencias relacionadas con los controles implantados.
- Informar sobre riesgos, vulnerabilidades o incidentes detectados.

8.4. Responsables de procesos y activos

Los responsables de procesos y activos serán responsables de conocer y gestionar los riesgos asociados a los recursos bajo su responsabilidad.

Entre sus funciones se incluyen:

- Identificar los activos y procesos bajo su responsabilidad.
- Determinar la importancia y criticidad de los activos.
- Participar en la evaluación de riesgos.
- Definir los requisitos de seguridad aplicables.
- Autorizar, cuando corresponda, el acceso a la información bajo su responsabilidad.
- Participar en la revisión periódica de los controles aplicables.
- Comunicar cambios relevantes que puedan afectar a la seguridad.

8.5. Recursos Humanos

El área de Recursos Humanos colaborará con el Responsable de Seguridad y las demás áreas implicadas en aquellas actividades relacionadas con la seguridad de la información durante el ciclo de vida de las personas dentro de la organización.

Entre sus responsabilidades se incluyen:

- Apoyar la comunicación de las responsabilidades de seguridad.
- Coordinar las actividades de formación y concienciación junto con el área responsable de seguridad.
- Gestionar, junto con las áreas correspondientes, los procesos de incorporación, cambio de funciones y salida de empleados.
- Mantener los registros necesarios relacionados con la formación y aceptación de las obligaciones de seguridad.

8.6. Usuarios

Todos los empleados, colaboradores y usuarios con acceso a los recursos de PearTrees Medical Services serán responsables de cumplir las políticas, normas y procedimientos de seguridad aplicables.

Entre sus responsabilidades se incluyen:

- Proteger las credenciales y medios de autenticación asignados.
- Utilizar los sistemas y recursos de acuerdo con las normas establecidas.
- Proteger la información a la que tengan acceso.

- Evitar accesos, usos o divulgaciones no autorizadas.
- Comunicar inmediatamente cualquier incidente o sospecha de incidente de seguridad.
- Participar en las actividades de formación y concienciación establecidas.
- Cumplir las instrucciones de seguridad aplicables a sus funciones.

8.7. Proveedores y terceros

Los proveedores y terceros que tengan acceso a información, sistemas, instalaciones o servicios incluidos en el alcance del SGSI deberán cumplir los requisitos de seguridad establecidos por PearTrees Medical Services.

Las responsabilidades específicas de los terceros deberán quedar definidas mediante contratos, acuerdos de nivel de servicio, acuerdos de confidencialidad u otros mecanismos documentales cuando corresponda.

8.8. Independencia y segregación de funciones

PearTrees Medical Services establecerá una adecuada segregación de funciones cuando la naturaleza de las actividades o el nivel de riesgo lo requiera.

Cuando sea necesario, las funciones de solicitud, aprobación, implementación y revisión de determinadas operaciones deberán estar separadas para reducir el riesgo de errores, abuso de privilegios o actuaciones no autorizadas.

8.9. Comunicación de responsabilidades

Las responsabilidades y autoridades relacionadas con la seguridad de la información deberán ser comunicadas a las personas correspondientes y revisadas cuando se produzcan cambios organizativos, tecnológicos o funcionales que puedan afectar al SGSI.

La organización mantendrá información documentada suficiente para demostrar la asignación de las responsabilidades relevantes.

8.10. Matriz de responsabilidades

Las responsabilidades detalladas de los diferentes roles podrán desarrollarse mediante una matriz de responsabilidades del SGSI, en la que se establecerán las funciones de cada área respecto de los principales procesos de seguridad.

La matriz deberá mantenerse actualizada y utilizarse como mecanismo complementario a la presente política.

9. Compromisos y directrices de seguridad

PearTrees Medical Services establecerá y mantendrá medidas organizativas, técnicas y físicas destinadas a proteger la información y los activos incluidos en el alcance del Sistema de Gestión de Seguridad de la Información (SGSI).

Las medidas de seguridad deberán seleccionarse y mantenerse de acuerdo con los riesgos identificados, los requisitos aplicables, la criticidad de los activos y las necesidades de la organización.

9.1. Gestión de activos

PearTrees Medical Services mantendrá un inventario actualizado de los activos relevantes para la seguridad de la información.

Los activos deberán contar con un responsable identificado y, cuando corresponda, con información relativa a su criticidad, ubicación, clasificación y requisitos de protección.

La organización establecerá mecanismos para gestionar los activos durante todo su ciclo de vida, incluyendo su incorporación, utilización, mantenimiento, transferencia y retirada.

Los activos deberán utilizarse exclusivamente para fines autorizados y de acuerdo con las políticas y normas de seguridad establecidas.

9.2. Clasificación y protección de la información

La información deberá clasificarse de acuerdo con su sensibilidad, criticidad, requisitos legales o contractuales y consecuencias potenciales de una pérdida de confidencialidad, integridad o disponibilidad.

PearTrees Medical Services establecerá criterios para determinar las medidas de protección aplicables a cada categoría de información.

La información deberá ser tratada, almacenada, transmitida, compartida y eliminada de acuerdo con su clasificación y los requisitos de seguridad correspondientes.

Cuando resulte necesario, se utilizarán mecanismos de protección adicionales, incluyendo controles de acceso, cifrado u otras medidas adecuadas al riesgo.

9.3. Control de acceso

El acceso a los sistemas y a la información se gestionará de acuerdo con los principios de mínimo privilegio y necesidad de conocer.

Los accesos deberán:

- Estar autorizados antes de su concesión.
- Estar asociados a una identidad individual, salvo excepciones justificadas.
- Ser adecuados a las funciones desempeñadas.
- Ser revisados periódicamente.
- Ser modificados o revocados cuando cambien las necesidades de acceso.
- Ser revocados cuando finalice la relación del usuario con la organización.

Los accesos privilegiados deberán estar sujetos a medidas de control reforzadas y a un nivel de supervisión acorde con el riesgo.

Cuando sea técnicamente viable y adecuado al riesgo, se utilizarán mecanismos de autenticación multifactor para proteger los sistemas y servicios de mayor criticidad.

9.4. Gestión de credenciales

Las credenciales y mecanismos de autenticación deberán protegerse frente a pérdida, divulgación, utilización indebida o acceso no autorizado.

Los usuarios serán responsables de mantener la confidencialidad de sus credenciales y no deberán compartirlas con otras personas.

Las cuentas y mecanismos de autenticación deberán gestionarse durante todo su ciclo de vida y estarán sujetos a los requisitos de seguridad definidos por la organización.

9.5. Seguridad de sistemas y redes

Los sistemas de información y las infraestructuras de comunicaciones deberán diseñarse, configurarse, operar y mantenerse aplicando medidas de seguridad adecuadas a los riesgos identificados.

La organización establecerá medidas destinadas, entre otros fines, a:

- Proteger las redes y sistemas frente a accesos no autorizados.
- Mantener configuraciones seguras.
- Gestionar actualizaciones y parches de seguridad.
- Detectar actividades anómalas cuando resulte necesario.
- Proteger los sistemas frente a código malicioso.

- Mantener registros de actividad relevantes.
- Reducir la exposición innecesaria de servicios y sistemas.
- Proteger las comunicaciones y los datos durante su transmisión cuando corresponda.

9.6. Gestión de vulnerabilidades

PearTrees Medical Services establecerá un proceso para identificar, evaluar, priorizar y tratar vulnerabilidades que puedan afectar a los activos incluidos en el alcance del SGSI.

La prioridad de tratamiento deberá determinarse considerando, entre otros factores:

- Criticidad del activo.
- Severidad de la vulnerabilidad.
- Exposición del activo.
- Probabilidad de explotación.
- Impacto potencial para la organización.
- Existencia de medidas compensatorias.

Las vulnerabilidades críticas deberán ser tratadas con prioridad y dentro de los plazos establecidos por la organización.

9.7. Gestión de cambios

Los cambios que puedan afectar a la seguridad de la información deberán ser identificados, evaluados y gestionados de forma controlada.

Antes de realizar cambios relevantes en sistemas, aplicaciones, infraestructuras o servicios, deberán considerarse los posibles impactos sobre la seguridad y, cuando corresponda, deberán definirse medidas de mitigación.

Los cambios deberán quedar registrados de acuerdo con los procedimientos establecidos.

9.8. Desarrollo y adquisición de sistemas

Los requisitos de seguridad deberán considerarse durante la adquisición, desarrollo, modificación y puesta en funcionamiento de sistemas y aplicaciones.

Cuando corresponda, deberán evaluarse los riesgos asociados al desarrollo o adquisición de soluciones tecnológicas y establecerse medidas destinadas a garantizar su seguridad durante todo su ciclo de vida.

Los sistemas no deberán ponerse en producción sin haber evaluado los requisitos de seguridad aplicables y los riesgos relevantes.

9.9. Gestión de incidentes de seguridad

PearTrees Medical Services mantendrá un proceso formal para gestionar los incidentes y eventos de seguridad de la información.

El proceso deberá permitir:

1. Detectar y comunicar eventos de seguridad.
2. Registrar y clasificar los incidentes.
3. Evaluar su impacto y criticidad.
4. Contener y erradicar las amenazas.
5. Recuperar los servicios afectados.
6. Documentar las actuaciones realizadas.
7. Analizar las causas y consecuencias.
8. Identificar lecciones aprendidas y oportunidades de mejora.

Los incidentes deberán comunicarse por los canales establecidos y gestionarse de acuerdo con su nivel de criticidad.

9.10. Continuidad y recuperación

La organización establecerá medidas destinadas a mantener la disponibilidad de la información y de los servicios críticos ante situaciones que puedan afectar a su funcionamiento normal.

Se establecerán mecanismos de:

- Copia de seguridad.
- Recuperación de información.
- Recuperación de sistemas.
- Continuidad de servicios críticos.
- Prueba periódica de los mecanismos de recuperación.

Las medidas de continuidad deberán estar alineadas con la criticidad de los procesos y con los riesgos identificados.

9.11. Copias de seguridad

PearTrees Medical Services establecerá mecanismos de copia de seguridad adecuados para proteger la información y permitir su recuperación ante pérdida, corrupción, destrucción o indisponibilidad.

Las copias deberán protegerse frente a accesos no autorizados, modificación, destrucción o pérdida.

La organización realizará pruebas periódicas de restauración para verificar que las copias disponibles permiten recuperar la información y los servicios para los que fueron establecidas.

Los resultados de las pruebas deberán quedar registrados y cualquier deficiencia identificada deberá ser objeto de seguimiento.

9.12. Seguridad física

Las instalaciones y áreas que alberguen información o activos relevantes para el SGSI deberán contar con medidas de seguridad física y ambiental adecuadas a los riesgos existentes.

Estas medidas podrán incluir controles destinados a prevenir:

- Accesos físicos no autorizados.
- Robo o pérdida de activos.
- Daños accidentales o intencionados.
- Interrupciones de suministro.
- Condiciones ambientales que puedan afectar a los sistemas.

El acceso a áreas restringidas deberá limitarse a las personas autorizadas.

9.13. Teletrabajo y dispositivos fuera de las instalaciones

El acceso remoto y el trabajo fuera de las instalaciones deberán realizarse mediante mecanismos que proporcionen un nivel de protección adecuado a la información y a los sistemas utilizados.

Los dispositivos utilizados fuera de las instalaciones deberán cumplir los requisitos de seguridad establecidos por la organización.

Los usuarios deberán adoptar medidas adecuadas para evitar la exposición, pérdida o acceso no autorizado a la información durante el trabajo remoto.

9.14. Seguridad de proveedores y terceros

Los proveedores y terceros que puedan acceder a información, sistemas o instalaciones incluidas en el alcance deberán ser evaluados desde el punto de vista de la seguridad de la información en función del riesgo asociado.

Cuando corresponda, los contratos y acuerdos deberán establecer requisitos relacionados con:

- Confidencialidad.
- Protección de la información.
- Control de accesos.
- Gestión de incidentes.
- Protección de datos.
- Continuidad del servicio.
- Notificación de incidentes.
- Devolución o eliminación de información.
- Derecho de auditoría o mecanismos equivalentes de supervisión.

Los proveedores críticos deberán ser objeto de seguimiento periódico de acuerdo con su nivel de riesgo.

9.15. Formación y concienciación

PearTrees Medical Services proporcionará formación y actividades de concienciación adecuadas a las funciones y responsabilidades de las personas que desarrollen actividades para la organización.

Las actividades podrán incluir:

- Formación inicial.
- Formación periódica.
- Campañas de concienciación.
- Comunicaciones sobre amenazas relevantes.
- Simulaciones o ejercicios de seguridad.

- Formación específica para funciones con responsabilidades especiales.

La organización mantendrá evidencias de las actividades realizadas y evaluará, cuando corresponda, su eficacia.

9.16. Protección de datos e información sensible

La información que esté sujeta a requisitos legales, reglamentarios o contractuales específicos deberá recibir medidas de protección adecuadas a dichos requisitos.

PearTrees Medical Services establecerá mecanismos destinados a prevenir el acceso, tratamiento, divulgación, conservación o eliminación no autorizados de dicha información.

Los requisitos específicos de protección de datos serán desarrollados en las políticas, procedimientos y controles correspondientes.

9.17. Registros y monitorización

La organización establecerá mecanismos para generar, conservar y proteger los registros necesarios para garantizar la trazabilidad de las actividades relevantes para la seguridad de la información.

Los registros de actividad y monitorización deberán gestionarse teniendo en cuenta su finalidad, criticidad, requisitos legales y necesidades de investigación de incidentes.

El acceso a los registros deberá estar restringido a las personas autorizadas.

9.18. Uso aceptable de los recursos

Los recursos tecnológicos y de información proporcionados por *PearTrees Medical Services* deberán utilizarse de manera responsable, segura y conforme a las finalidades autorizadas.

Los usuarios deberán respetar las normas establecidas para el uso de equipos, sistemas, redes, aplicaciones, servicios de comunicación y demás recursos corporativos.

Los usos prohibidos o restringidos serán desarrollados en la correspondiente política o norma de uso aceptable.

9.19. Eliminación y destrucción segura

La información y los activos que hayan dejado de ser necesarios deberán eliminarse, destruirse, reutilizarse o retirarse de forma segura, teniendo en cuenta su clasificación y los requisitos aplicables.

La eliminación deberá impedir, cuando corresponda, la recuperación no autorizada de la información.

9.20. Cumplimiento y revisión de controles

Los controles de seguridad establecidos por *PearTrees Medical Services* deberán ser objeto de seguimiento y revisión para verificar su adecuación y eficacia.

Las deficiencias identificadas deberán registrarse y ser tratadas mediante las acciones correspondientes, teniendo en cuenta su impacto y nivel de riesgo.

La organización utilizará los resultados obtenidos para mejorar progresivamente las medidas de seguridad y la eficacia del SGSI.

10. Cumplimiento de requisitos aplicables

PearTrees Medical Services se compromete a identificar, evaluar, mantener y cumplir los requisitos legales, reglamentarios, contractuales y otros requisitos aplicables a sus actividades y al Sistema de Gestión de Seguridad de la Información (SGSI).

La organización deberá determinar aquellos requisitos que puedan afectar a la confidencialidad, integridad, disponibilidad y protección de la información, así como las obligaciones derivadas de las relaciones contractuales y de las necesidades y expectativas de las partes interesadas relevantes.

10.1. Requisitos legales y reglamentarios

PearTrees Medical Services identificará y mantendrá actualizados los requisitos legales y reglamentarios aplicables a sus actividades, a la información tratada y a los servicios proporcionados.

Entre las materias que podrán resultar relevantes para la organización se incluyen:

- Protección de datos personales.
- Seguridad de la información.
- Conservación y protección de registros.
- Seguridad y continuidad de los servicios.

- Requisitos específicos aplicables al sector en el que desarrolla sus actividades.
- Obligaciones relacionadas con la notificación y gestión de determinados incidentes, cuando resulten aplicables.

Los requisitos identificados deberán ser evaluados y comunicados a las áreas responsables de su cumplimiento.

10.2. Protección de datos personales

Cuando *PearTrees Medical Services* trate datos personales, deberá establecer y mantener las medidas organizativas y técnicas necesarias para garantizar su protección de acuerdo con los requisitos legales aplicables.

La organización deberá considerar, entre otros aspectos:

- Licitud y finalidad del tratamiento.
- Control de acceso a los datos.
- Confidencialidad.
- Integridad y disponibilidad.
- Conservación y eliminación.
- Gestión de incidentes y posibles brechas de seguridad.
- Derechos de los interesados.
- Relación con encargados del tratamiento y otros terceros.

Los requisitos específicos relacionados con la protección de datos serán desarrollados mediante la documentación y los controles correspondientes.

10.3. Requisitos contractuales

Los contratos y acuerdos establecidos con clientes, proveedores, colaboradores y otros terceros deberán ser revisados para identificar obligaciones relacionadas con la seguridad de la información.

Cuando corresponda, los contratos deberán establecer requisitos relativos a:

- Confidencialidad.
- Protección de la información.
- Control de accesos.

- Gestión de incidentes.
- Continuidad del servicio.
- Protección de datos.
- Subcontratación.
- Devolución o eliminación de información.
- Cumplimiento de requisitos de seguridad establecidos por *PearTrees Medical Services*.

Los requisitos contractuales relevantes deberán ser comunicados a las áreas responsables de su cumplimiento y seguimiento.

10.4. Requisitos de las partes interesadas

Las necesidades y expectativas de las partes interesadas que sean relevantes para el SGSI deberán ser identificadas y evaluadas.

Cuando dichas necesidades se traduzcan en requisitos de seguridad de la información, deberán incorporarse al marco de gestión correspondiente y ser objeto de seguimiento.

10.5. ISO/IEC 27001

PearTrees Medical Services adopta ISO/IEC 27001:2022 como marco de referencia para el establecimiento, implantación, mantenimiento y mejora de su Sistema de Gestión de Seguridad de la Información.

La presente política constituye uno de los elementos documentales del SGSI y deberá mantenerse alineada con los requisitos aplicables de la norma.

La adopción de ISO/IEC 27001 como marco de referencia no implica por sí misma que *PearTrees Medical Services* disponga de una certificación, salvo que esta haya sido formalmente obtenida.

10.6. Estándares y buenas prácticas

La organización podrá utilizar estándares, marcos y buenas prácticas reconocidos para complementar el SGSI y facilitar la definición, implantación y evaluación de medidas de seguridad.

Entre los marcos de referencia que podrán utilizarse, cuando resulten adecuados a las necesidades de la organización, se encuentran:

- ISO/IEC 27002 para la orientación sobre controles de seguridad de la información.
- ISO/IEC 27005 para la gestión de riesgos de seguridad de la información.
- NIST *Cybersecurity Framework* para apoyar la gestión y comunicación del riesgo de ciberseguridad.
- NIST SP 800-61 para la gestión y respuesta ante incidentes de seguridad.

La utilización de estos marcos deberá justificarse en función de las necesidades y objetivos del SGSI y no supondrá automáticamente la existencia de una obligación legal o reglamentaria.

10.7. Evaluación del cumplimiento

PearTrees Medical Services establecerá mecanismos para evaluar periódicamente el grado de cumplimiento de los requisitos aplicables.

Las evaluaciones podrán realizarse mediante:

- Revisiones internas.
- Auditorías.
- Evaluaciones de cumplimiento.
- Revisiones contractuales.
- Análisis de requisitos legales y reglamentarios.
- Revisiones de controles.
- Análisis de incidentes y desviaciones.

Los incumplimientos identificados deberán ser registrados, evaluados y tratados de acuerdo con su naturaleza y nivel de riesgo.

10.8. Gestión de incumplimientos

Cuando se detecte un incumplimiento de un requisito aplicable, la organización deberá:

1. Registrar el incumplimiento.
2. Evaluar sus consecuencias.
3. Determinar las causas cuando resulte necesario.
4. Establecer las acciones correspondientes.

5. Asignar responsables y plazos.
6. Realizar el seguimiento de las acciones.
7. Verificar su resolución y eficacia.

Cuando un incumplimiento pueda afectar significativamente a la seguridad de la información, deberá comunicarse a la Dirección y a las partes responsables correspondientes.

10.9. Registro de requisitos aplicables

La organización mantendrá información documentada sobre los requisitos legales, reglamentarios, contractuales y otros requisitos relevantes para el SGSI.

El registro deberá mantenerse actualizado y deberá identificar, cuando resulte apropiado:

- Requisito.
- Fuente.
- Ámbito de aplicación.
- Área responsable.
- Información o procesos afectados.
- Controles relacionados.
- Evidencias de cumplimiento.
- Fecha de revisión.

El registro será utilizado como referencia para las actividades de evaluación de cumplimiento y auditoría del SGSI.

11. Gestión de excepciones

PearTrees Medical Services reconoce que pueden existir situaciones excepcionales en las que no resulte posible aplicar de forma inmediata determinados requisitos establecidos en esta política, debido a limitaciones técnicas, operativas, contractuales u otras circunstancias justificadas.

Las excepciones no deberán utilizarse para evitar de forma sistemática el cumplimiento de los requisitos de seguridad y deberán gestionarse mediante un proceso formal basado en el riesgo.

11.1. Solicitud de una excepción

Cualquier excepción a los requisitos establecidos en esta política deberá ser solicitada y documentada antes de su aplicación, siempre que las circunstancias lo permitan.

La solicitud deberá incluir, como mínimo:

- Requisito objeto de la excepción.
- Sistema, proceso, activo o información afectada.
- Motivo y justificación de la excepción.
- Duración prevista.
- Riesgos asociados.
- Medidas compensatorias propuestas, cuando sean necesarias.
- Responsable de la excepción.
- Nivel de aprobación requerido.

11.2. Evaluación del riesgo

Toda excepción deberá ser evaluada desde el punto de vista de la seguridad de la información.

La evaluación deberá considerar:

- Probabilidad de que se materialice el riesgo.
- Impacto potencial.
- Criticidad de los activos o procesos afectados.
- Duración de la excepción.
- Existencia de controles compensatorios.
- Requisitos legales, reglamentarios o contractuales que puedan verse afectados.

No podrá aprobarse una excepción cuando implique el incumplimiento de un requisito legal o reglamentario que no admita dicha excepción.

11.3. Medidas compensatorias

Cuando una excepción suponga un aumento del riesgo, deberán establecerse, cuando sea posible, medidas compensatorias destinadas a reducir dicho riesgo hasta un nivel aceptable.

Las medidas compensatorias deberán quedar documentadas y contar con un responsable de su implantación y seguimiento.

11.4. Aprobación

Las excepciones deberán ser aprobadas por la autoridad correspondiente en función del nivel de riesgo.

Las excepciones que impliquen riesgos significativos deberán ser elevadas a la Dirección para su aceptación formal.

La aprobación de una excepción deberá quedar registrada y no supondrá la eliminación permanente del requisito afectado.

11.5. Duración y revisión

Las excepciones deberán tener una duración limitada y una fecha prevista de revisión o finalización.

No se permitirán excepciones indefinidas salvo que exista una justificación formal y una revisión periódica de su necesidad y riesgo.

El responsable de la excepción deberá realizar el seguimiento de las medidas compensatorias y comunicar cualquier cambio relevante en el nivel de riesgo.

11.6. Registro de excepciones

PearTrees Medical Services mantendrá un registro de las excepciones aprobadas.

Como mínimo, el registro deberá incluir:

Campo	Información
ID de excepción	Identificador único
Requisito afectado	Requisito objeto de excepción
Activo/proceso	Elemento afectado
Justificación	Motivo de la excepción
Riesgo	Riesgo asociado

Medidas compensatorias	Controles adicionales
Responsable	Responsable de la excepción
Aprobador	Autoridad que aprueba
Inicio	Fecha de inicio
Fin/revisión	Fecha prevista
Estado	Abierta / Cerrada

11.7. Revisión de excepciones

Las excepciones serán revisadas periódicamente para determinar si continúan siendo necesarias.

Cuando desaparezcan las circunstancias que motivaron una excepción, deberán adoptarse las medidas necesarias para recuperar el cumplimiento del requisito original.

Las excepciones vencidas deberán cerrarse formalmente y conservarse como información documentada de acuerdo con los criterios de conservación establecidos por la organización.

12. Comunicación y aceptación de la política

PearTrees Medical Services garantizará que la presente Política de Seguridad de la Información sea comunicada, puesta a disposición y comprendida por las personas y partes interesadas para las que resulte relevante.

La organización establecerá mecanismos adecuados para garantizar que las personas sujetas a esta política conozcan sus responsabilidades en materia de seguridad de la información.

12.1. Comunicación interna

La Política de Seguridad de la Información será comunicada a los empleados y demás personas que desarrollen actividades para *PearTrees Medical Services* y que estén sujetas a sus requisitos.

La comunicación podrá realizarse mediante:

- Publicación en los sistemas internos de información.
- Portal corporativo o intranet.

- Comunicaciones internas.
- Formación y sesiones de concienciación.
- Procesos de incorporación de nuevos empleados.
- Comunicaciones específicas ante modificaciones relevantes.

La organización deberá garantizar que la versión vigente de la política se encuentre disponible para las personas autorizadas.

12.2. Conocimiento y aceptación

Las personas a las que resulte aplicable esta política deberán conocer sus responsabilidades y obligaciones de seguridad.

Cuando resulte necesario, PearTrees Medical Services establecerá mecanismos para obtener evidencia de que la política ha sido comunicada y aceptada, tales como:

- Registro de aceptación.
- Confirmación electrónica.
- Firma de documentación.
- Registro de asistencia a sesiones de formación.
- Confirmación durante procesos de incorporación.
- Otros mecanismos equivalentes.

La aceptación de la política no exime a las personas de cumplir la legislación, regulación, contratos, procedimientos y demás requisitos aplicables.

12.3. Comunicación a terceros

Los proveedores, colaboradores y terceros que tengan acceso a información, sistemas, instalaciones o servicios incluidos en el alcance recibirán los requisitos de seguridad que resulten aplicables a sus funciones.

Cuando corresponda, dichos requisitos serán establecidos mediante:

- Contratos.
- Acuerdos de confidencialidad.
- Acuerdos de nivel de servicio.
- Políticas y normas aplicables.

- Procedimientos de acceso.
- Otros mecanismos documentados.

Los requisitos comunicados deberán ser proporcionales al nivel de acceso y riesgo asociado al tercero.

12.4. Disponibilidad de la política

La versión vigente de la política deberá estar disponible en un repositorio autorizado por la organización.

El acceso a la documentación deberá gestionarse de forma que se evite la utilización de versiones obsoletas.

Cuando la política sea actualizada, la organización deberá establecer los mecanismos necesarios para sustituir o identificar adecuadamente las versiones anteriores.

12.5. Comunicación externa

La política podrá ponerse a disposición de partes interesadas externas cuando resulte apropiado y no exista una restricción derivada de su clasificación o de otros requisitos.

La publicación externa deberá ser autorizada por la organización y deberá utilizar la versión aprobada para tal finalidad.

12.6. Comunicación de cambios

Las modificaciones relevantes de la política deberán ser comunicadas a las personas y partes interesadas afectadas.

Cuando un cambio implique nuevas obligaciones o responsabilidades, la organización deberá proporcionar, cuando sea necesario, formación o información adicional para facilitar su correcta aplicación.

12.7. Evidencias de comunicación

PearTrees Medical Services conservará información documentada que permita demostrar, cuando sea necesario, que la política ha sido comunicada y puesta a disposición de las personas correspondientes.

Las evidencias podrán incluir:

- Registros de publicación.
- Registros de aceptación.

- Registros de formación.
- Comunicaciones internas.
- Confirmaciones electrónicas.
- Registros de incorporación de empleados.
- Evidencias de comunicación a terceros.

Estas evidencias podrán utilizarse durante auditorías, revisiones internas y actividades de evaluación del cumplimiento del SGSI.

13. Revisión y mejora continua

PearTrees Medical Services establecerá mecanismos para garantizar que la presente Política de Seguridad de la Información se mantenga adecuada, eficaz y alineada con las necesidades de la organización, los riesgos de seguridad de la información y los requisitos aplicables.

La política será objeto de revisión periódica y podrá ser revisada de forma extraordinaria cuando se produzcan cambios que puedan afectar significativamente a su contenido o aplicabilidad.

13.1. Revisión periódica

La Política de Seguridad de la Información será revisada al menos una vez al año por el Responsable de Seguridad de la Información y será sometida a la aprobación de la Dirección cuando se produzcan modificaciones relevantes.

La revisión tendrá como objetivo determinar si la política:

- Continúa siendo adecuada para el propósito de la organización.
- Continúa siendo coherente con el contexto del SGSI.
- Refleja adecuadamente los riesgos actuales.
- Continúa cubriendo los requisitos aplicables.
- Mantiene la coherencia con los objetivos de seguridad.
- Sigue siendo adecuada respecto a las necesidades de las partes interesadas.
- Requiere modificaciones como consecuencia de cambios organizativos o tecnológicos.

13.2. Revisión extraordinaria

La política podrá ser revisada fuera del ciclo ordinario cuando se produzcan circunstancias que puedan afectar significativamente a la seguridad de la información.

Entre estas circunstancias se incluyen:

- Incidentes de seguridad relevantes.
- Cambios significativos en el perfil de riesgo.
- Cambios en la estructura o actividad de la organización.
- Incorporación de nuevas ubicaciones o servicios.
- Cambios tecnológicos relevantes.
- Modificaciones de requisitos legales o reglamentarios.
- Cambios contractuales significativos.
- Resultados de auditorías.
- No conformidades o incumplimientos relevantes.
- Cambios significativos en proveedores críticos.
- Resultados de revisiones por la Dirección.

13.3. Evaluación de la eficacia

Durante la revisión se evaluará la eficacia de la política y de las medidas de seguridad relacionadas con ella.

Para ello podrán utilizarse, entre otras, las siguientes fuentes de información:

- Indicadores y objetivos del SGSI.
- Resultados de auditorías.
- Resultados de evaluaciones de riesgos.
- Registros de incidentes.
- Resultados de pruebas de continuidad y recuperación.
- Evaluaciones de cumplimiento.
- Resultados de revisiones de accesos.
- Vulnerabilidades identificadas.

- Incumplimientos y acciones correctivas.
- Comentarios de las partes interesadas.
- Resultados de la revisión por la Dirección.

13.4. Gestión de modificaciones

Las modificaciones de la política deberán ser documentadas mediante el correspondiente control de versiones.

Cada nueva versión deberá indicar, cuando corresponda:

- Número de versión.
- Fecha de modificación.
- Descripción de los cambios.
- Responsable de la modificación.
- Responsable de revisión.
- Responsable de aprobación.

Las versiones obsoletas deberán conservarse de acuerdo con los criterios de gestión documental establecidos por la organización, evitando que puedan confundirse con la versión vigente.

13.5. Acciones correctivas y de mejora

Cuando la revisión de la política o del SGSI identifique deficiencias, incumplimientos o oportunidades de mejora, se establecerán las acciones necesarias para corregirlas o mejorar el desempeño de la organización.

Las acciones deberán:

- Ser registradas.
- Tener un responsable asignado.
- Disponer de un plazo de ejecución.
- Ser objeto de seguimiento.
- Ser evaluadas para determinar su eficacia cuando corresponda.

Cuando una deficiencia tenga su origen en un cambio significativo del riesgo, deberá evaluarse si es necesario modificar la política, los controles o cualquier otro elemento del SGSI.

13.6. Revisión por la Dirección

Los resultados relevantes relacionados con la Política de Seguridad de la Información serán considerados durante las revisiones del SGSI por parte de la Dirección.

La Dirección evaluará, entre otros aspectos:

- Adecuación y eficacia del SGSI.
- Cumplimiento de los objetivos de seguridad.
- Evolución de los riesgos.
- Resultados de auditorías.
- Incidentes relevantes.
- Estado de las acciones correctivas.
- Necesidades de recursos.
- Cambios que puedan afectar al SGSI.
- Oportunidades de mejora.

Las decisiones y acciones derivadas de la revisión deberán quedar documentadas.

13.7. Comunicación de las modificaciones

Las modificaciones aprobadas que afecten a las responsabilidades o requisitos de seguridad deberán ser comunicadas a las personas y partes interesadas correspondientes.

Cuando resulte necesario, se realizarán actividades adicionales de formación o concienciación para facilitar la correcta aplicación de los cambios.

13.8. Evidencias

PearTrees Medical Services conservará información documentada suficiente para demostrar la revisión y evolución de la política.

Entre las evidencias podrán incluirse:

- Historial de versiones.
- Actas de revisión.
- Registros de aprobación.

- Informes de auditoría.
- Registros de acciones correctivas.
- Informes de indicadores.
- Resultados de evaluación de riesgos.
- Registros de incidentes.
- Actas de revisión por la Dirección.
- Evidencias de comunicación de cambios.

14. Estructura documental y políticas específicas de seguridad

La presente Política de Seguridad de la Información constituye el documento de nivel superior que establece los principios, compromisos y directrices generales aplicables a la gestión de la seguridad de la información en PearTrees Medical Services.

Los requisitos establecidos en esta política podrán desarrollarse mediante políticas específicas, normas, procedimientos, instrucciones y otros documentos del Sistema de Gestión de Seguridad de la Información (SGSI).

14.1. Estructura documental

La documentación relacionada con la seguridad de la información se organizará, de forma general, en los siguientes niveles:

Nivel 1 — Política general

Documento de carácter estratégico que establece:

- Compromiso de la Dirección.
- Principios de seguridad.
- Objetivos generales.
- Alcance.
- Responsabilidades.
- Directrices generales.
- Compromisos de cumplimiento.

- Criterios de revisión y mejora.

La presente Política de Seguridad de la Información constituye el documento principal de este nivel.

Nivel 2 — Políticas y normas específicas

Desarrollan los requisitos establecidos en la política general para ámbitos concretos de seguridad.

Entre ellas podrán incluirse:

- Política de Control de Acceso.
- Política de Clasificación y Protección de la Información.
- Política de Uso Aceptable de los Recursos.
- Política de Gestión de Incidentes.
- Política de Copias de Seguridad.
- Política de Seguridad de Proveedores.
- Política de Seguridad en el Teletrabajo.
- Política de Gestión de Dispositivos.
- Política de Gestión de Vulnerabilidades.
- Política de Seguridad Física.
- Política de Continuidad y Recuperación.

Estas políticas deberán ser coherentes con la presente política y no podrán establecer requisitos contradictorios.

Nivel 3 — Procedimientos

Los procedimientos definirán la forma en que se deberán ejecutar las actividades necesarias para cumplir los requisitos establecidos en las políticas.

Podrán incluir, entre otros:

- Procedimiento de alta, modificación y baja de usuarios.
- Procedimiento de revisión de permisos.
- Procedimiento de gestión de incidentes.
- Procedimiento de gestión de vulnerabilidades.

- Procedimiento de realización y restauración de copias de seguridad.
- Procedimiento de gestión de proveedores.
- Procedimiento de gestión de excepciones.
- Procedimiento de gestión de cambios.

Los procedimientos deberán definir, cuando resulte necesario, responsables, actividades, entradas, salidas, registros y criterios de actuación.

Nivel 4 — Registros y evidencias

Los procesos de seguridad deberán generar información documentada que permita demostrar la ejecución de las actividades y la eficacia de los controles.

Entre las evidencias podrán encontrarse:

- Registros de incidentes.
- Registros de accesos.
- Revisiones de permisos.
- Informes de vulnerabilidades.
- Registros de copias de seguridad.
- Resultados de pruebas de restauración.
- Registros de formación.
- Registros de aceptación de políticas.
- Informes de auditoría.
- Registros de excepciones.
- Registros de riesgos.
- Acciones correctivas y de mejora.

14.2. Relación entre documentos

Los documentos del SGSI deberán mantener una relación coherente entre requisitos, controles, procedimientos y evidencias.

La organización procurará mantener la siguiente trazabilidad:

Requisito → Política → Control → Procedimiento → Evidencia → Evaluación

Esta trazabilidad permitirá demostrar que los requisitos establecidos por la organización se traducen en medidas concretas y que dichas medidas pueden ser verificadas.

14.3. Gestión documental

La documentación relacionada con la seguridad de la información deberá gestionarse de forma controlada.

Los documentos deberán disponer, cuando corresponda, de:

- Identificador.
- Título.
- Propietario o responsable.
- Versión.
- Fecha de aprobación.
- Fecha de revisión.
- Estado.
- Clasificación.
- Responsable de aprobación.

La organización deberá evitar el uso de documentos obsoletos y garantizar que las versiones vigentes estén disponibles para las personas autorizadas.

14.4. Coherencia entre políticas

Las políticas específicas deberán mantener coherencia con la Política General de Seguridad de la Información.

En caso de conflicto entre documentos, deberá realizarse una revisión formal para determinar cuál de ellos debe prevalecer y, cuando corresponda, actualizar la documentación afectada.

Los requisitos más restrictivos podrán aplicarse cuando estén justificados por el nivel de riesgo o por requisitos legales, reglamentarios o contractuales.

14.5. Responsabilidad sobre la documentación

Cada documento del SGSI deberá disponer de un responsable encargado de garantizar que su contenido:

- Se mantiene actualizado.

- Es coherente con los requisitos aplicables.
- Es revisado con la periodicidad establecida.
- Se encuentra disponible para las personas correspondientes.
- Es retirado o sustituido cuando deje de ser aplicable.

Las modificaciones deberán seguir el proceso de aprobación establecido.

14.6. Desarrollo progresivo del SGSI

PearTrees Medical Services podrá desarrollar progresivamente las políticas, procedimientos y demás documentación del SGSI de acuerdo con la evolución de sus riesgos, necesidades y recursos.

La ausencia de una política o procedimiento específico no exime del cumplimiento de los principios y requisitos establecidos en la presente Política General de Seguridad de la Información.

15. Aprobación, vigencia y control de versiones

La presente Política de Seguridad de la Información deberá ser aprobada formalmente por la Dirección de PearTrees Medical Services antes de su entrada en vigor.

La política será considerada un documento controlado del Sistema de Gestión de Seguridad de la Información (SGSI) y estará sujeta a los mecanismos de gestión documental establecidos por la organización.

15.1. Aprobación

La aprobación de la política corresponderá a la Dirección de PearTrees Medical Services.

La aprobación implicará el compromiso de la Dirección con los principios, objetivos y requisitos establecidos en el documento y con la disponibilidad de los recursos necesarios para su aplicación.

La aprobación deberá quedar registrada mediante firma, aprobación electrónica o mecanismo equivalente que permita demostrar la identidad de la persona responsable y la fecha de aprobación.

Registro de aprobación

Rol	Responsable	Fecha	Aprobación
-----	-------------	-------	------------

Dirección	Dirección de PearTrees Medical Services	Pendiente	Pendiente
Responsable de Seguridad	Responsable del SGSI	Pendiente	Revisión

15.2. Entrada en vigor

La política entrará en vigor en la fecha indicada en su registro de aprobación.

A partir de dicha fecha, las personas y áreas incluidas en su ámbito de aplicación deberán cumplir los requisitos establecidos en ella.

15.3. Vigencia

La política permanecerá vigente hasta que sea sustituida por una nueva versión aprobada.

La política será revisada como mínimo anualmente y adicionalmente cuando se produzcan circunstancias que puedan afectar significativamente a su contenido o aplicabilidad, de acuerdo con lo establecido en el apartado 13.

15.4. Control de versiones

Todas las modificaciones realizadas sobre la política deberán quedar registradas mediante un mecanismo de control de versiones.

El historial de modificaciones deberá permitir identificar, como mínimo:

- Número de versión.
- Fecha.
- Descripción del cambio.
- Responsable de modificación.
- Responsable de revisión.
- Responsable de aprobación.

Historial de versiones					
Versión	Fecha	Descripción	Elaborado por:	Revisado por:	Aprobado por:
0.1	25/08/26	Borrador inicial	Responsable del SGSI	Pendiente	Pendiente
1.0	Pendiente	Aprobación inicial	Pendiente	Pendiente	Dirección
1.1	Pendiente	Modificación	Pendiente	Pendiente	Dirección

15.5. Distribución y versiones obsoletas

La organización deberá garantizar que la versión vigente de la política se encuentre disponible en el repositorio autorizado correspondiente.

Las versiones obsoletas deberán identificarse adecuadamente para evitar su utilización accidental y deberán conservarse cuando sea necesario como evidencia del historial documental.

15.6. Propiedad del documento

La Política de Seguridad de la Información será propiedad de PearTrees Medical Services.

El Responsable del SGSI será responsable de coordinar su mantenimiento, revisión y actualización, sin perjuicio de la responsabilidad de aprobación que corresponde a la Dirección.

ANEXO A. DOCUMENTOS RELACIONADOS

El presente anexo identifica los principales documentos relacionados con la Política de Seguridad de la Información de PearTrees Medical Services.

Estos documentos desarrollan, complementan o proporcionan evidencia de los requisitos establecidos en la presente política y forman parte, cuando corresponda, del marco documental del Sistema de Gestión de Seguridad de la Información (SGSI).

La existencia y nivel de desarrollo de cada documento dependerá de las necesidades de la organización, los riesgos identificados y la evolución del SGSI.

A.1. Documentos de gobierno y gestión

Código	Documento	Descripción
PSI-001	Política de Seguridad de la Información	Documento principal que establece los principios, compromisos, objetivos y directrices generales del SGSI.
GRC-001	Contexto y partes interesadas del SGSI	Identifica el contexto interno y externo, las partes interesadas y sus requisitos relevantes para el SGSI.
GRC-002	Matriz de roles y responsabilidades del SGSI	Define las responsabilidades y autoridades de las diferentes áreas y roles relacionados con el SGSI.
GRC-003	Registro de requisitos aplicables	Identifica los requisitos legales, reglamentarios, contractuales y otros requisitos relevantes para el SGSI.
GRC-004	Registro de excepciones	Permite gestionar y realizar el seguimiento de las excepciones autorizadas a los requisitos de seguridad.

A.2. Documentos de gestión de riesgos

Código	Documento	Descripción
GRC-005	Metodología de gestión de riesgos	Define los criterios y metodología utilizados para identificar, analizar, evaluar y tratar los riesgos de seguridad de la información.

GRC-006	Registro de riesgos	Contiene los riesgos identificados, su valoración, tratamiento, responsables y estado.
GRC-007	Plan de tratamiento de riesgos	Define las acciones previstas para tratar los riesgos identificados y reducirlos hasta niveles aceptables.
GRC-008	Declaración de aplicabilidad (SoA)	Documenta los controles de seguridad considerados aplicables, su justificación y estado de implantación.

A.3. Políticas y normas específicas de seguridad

Código	Documento	Descripción
PSI-002	Política de Control de Acceso	Establece los principios y requisitos para la gestión de identidades, autenticación y autorizaciones.
PSI-003	Política de Clasificación y Protección de la Información	Establece los criterios para clasificar, tratar y proteger la información.
PSI-004	Política de Uso Aceptable	Define las condiciones de uso adecuado de los sistemas, dispositivos, redes y recursos corporativos.
PSI-005	Política de Gestión de Incidentes	Establece el marco general para la detección, comunicación, respuesta y aprendizaje derivado de incidentes de seguridad.
PSI-006	Política de Copias de Seguridad	Define los principios y requisitos generales para la realización, protección y recuperación de copias de seguridad.
PSI-007	Política de Gestión de Vulnerabilidades	Establece los criterios para identificar, evaluar, priorizar y tratar vulnerabilidades.
PSI-008	Política de Seguridad de Proveedores	Establece los requisitos de seguridad aplicables a proveedores y terceros.

PSI-009	Política de Teletrabajo y Acceso Remoto	Establece los requisitos de seguridad aplicables al trabajo remoto y al acceso a los recursos corporativos desde ubicaciones externas.
PSI-010	Política de Seguridad Física	Define los principios para proteger las instalaciones, equipos y áreas donde se gestionan activos de información.

A.4. Procedimientos

Código	Documento	Descripción
PR-SEC-001	Procedimiento de Gestión de Incidentes	Define las actividades necesarias para registrar, clasificar, contener, resolver y cerrar incidentes de seguridad.
PR-SEC-002	Procedimiento de Gestión de Vulnerabilidades	Define el proceso para identificar, valorar, priorizar y corregir vulnerabilidades.
PR-SEC-003	Procedimiento de Gestión de Excepciones	Define el proceso de solicitud, evaluación, aprobación, seguimiento y cierre de excepciones de seguridad.
PR-IT-001	Procedimiento de Alta, Modificación y Baja de Usuarios	Define el proceso para gestionar las cuentas y permisos durante el ciclo de vida de los usuarios.
PR-IT-002	Procedimiento de Revisión de Accesos	Define la metodología para revisar periódicamente los permisos y privilegios asignados.
PR-IT-003	Procedimiento de Copias de Seguridad y Restauración	Define las actividades relacionadas con la ejecución, supervisión y restauración de copias de seguridad.
PR-IT-004	Procedimiento de Gestión de Cambios	Establece las actividades necesarias para gestionar cambios que puedan afectar a sistemas y servicios.
PR-GRC-001	Procedimiento de Evaluación de Proveedores	Define los criterios para evaluar y revisar los riesgos de seguridad asociados a proveedores y terceros.

A.5. Registros y evidencias

Los procesos del SGSI deberán generar información documentada suficiente para demostrar la ejecución y eficacia de las actividades de seguridad.

Entre las principales evidencias se incluyen:

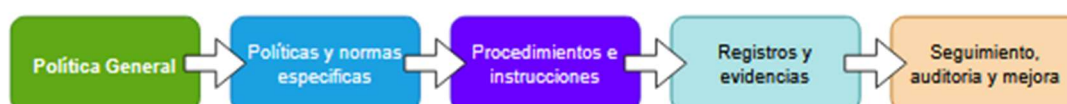
Código	Registro / evidencia	Finalidad
REG-001	Registro de activos	Mantener identificados los activos relevantes y sus responsables.
REG-002	Registro de riesgos	Mantener información sobre los riesgos identificados y su tratamiento.
REG-003	Registro de incidentes	Registrar y realizar el seguimiento de eventos e incidentes de seguridad.
REG-004	Registro de vulnerabilidades	Mantener información sobre vulnerabilidades identificadas y su tratamiento.
REG-005	Registro de formación y concienciación	Demostrar la realización de actividades de formación y concienciación.
REG-006	Registro de aceptación de políticas	Demostrar la comunicación y aceptación de las políticas aplicables.
REG-007	Registro de revisiones de acceso	Evidenciar la revisión periódica de permisos y privilegios.
REG-008	Registro de copias de seguridad	Evidenciar la ejecución y resultado de las operaciones de backup.
REG-009	Registro de pruebas de restauración	Demostrar la capacidad de recuperación de la información.
REG-010	Registro de excepciones	Mantener evidencia de las excepciones autorizadas y su seguimiento.
REG-011	Registro de acciones correctivas	Registrar las acciones destinadas a corregir incumplimientos y mejorar el SGSI.

REG-012	Registro de auditorías	Mantener evidencia de las auditorías y evaluaciones realizadas.
----------------	------------------------	---

A.6. Relación documental

Los documentos relacionados con el SGSI deberán mantener una relación coherente con la presente Política de Seguridad de la Información.

La estructura documental seguirá, con carácter general, la siguiente relación:



La documentación deberá mantenerse actualizada y sometida a los mecanismos de control documental establecidos por PearTrees Medical Services.

A.7. Estado de los documentos

Los documentos incluidos en este anexo representan la arquitectura documental de referencia del SGSI.

Cuando un documento todavía no haya sido desarrollado o implantado, deberá identificarse como pendiente de desarrollo, en desarrollo o no implantado, evitando presentar como evidencia de implantación un documento que únicamente haya sido definido como parte de la arquitectura prevista.

El estado de cada documento deberá ser objeto de seguimiento por el responsable correspondiente.

Estado documental

Estado	Significado
Vigente	Documento aprobado y actualmente aplicable.
En desarrollo	Documento en proceso de elaboración o revisión.
Pendiente	Documento identificado como necesario pero todavía no desarrollado.
Obsoleto	Documento sustituido por una versión posterior o que ha dejado de ser aplicable.

ANEXO B. MATRIZ DE TRAZABILIDAD CON ISO/IEC 27001:2022

El presente anexo establece la relación entre los requisitos de **ISO/IEC 27001:2022** relevantes para la Política de Seguridad de la Información de *PearTrees Medical Services* y los apartados desarrollados en el presente documento.

La matriz tiene como finalidad facilitar la revisión de la cobertura de los requisitos, mantener la trazabilidad documental y servir como herramienta de apoyo durante las actividades de revisión y auditoría del Sistema de Gestión de Seguridad de la Información (SGSI).

La existencia de una correspondencia en esta matriz no implica por sí misma que PearTrees Medical Services pueda afirmar la conformidad o certificación respecto de ISO/IEC 27001:2022. La evaluación de conformidad requiere valorar el conjunto del SGSI y la evidencia asociada a su implantación y funcionamiento.

B.1. Trazabilidad de los requisitos de las cláusulas 4 a 10

Requisito ISO/IEC 27001:2022	Tema	Cobertura en la política	Apartado relacionado	Evidencia / documento relacionado
4.1	Comprensión de la organización y su contexto	Parcial	4. Contexto y situación de la organización	GRC-001 Contexto del SGSI
4.2	Necesidades y expectativas de las partes interesadas	Parcial	4. Contexto y situación de la organización / 10.4	GRC-001 / GRC-003
4.3	Determinación del alcance del SGSI	Sí	3. Alcance	Documento de alcance del SGSI
4.4	Sistema de gestión de seguridad de la información	Sí	1, 4, 13 y 14	Documentación general del SGSI

5.1	Liderazgo y compromiso	Sí	6. Compromiso de la Dirección	Acta de revisión por Dirección / evidencias de recursos
5.2	Política	Sí	1, 2, 5, 6, 12 y 15	Política aprobada
5.3	Roles, responsabilidad es y autoridades	Sí	8. Roles, responsabilidad es y autoridades	GRC-002 Matriz de responsabilidad es
6.1.1	Acciones para abordar riesgos y oportunidades	Parcial	5.1, 6.4 y 13	Metodología de riesgos / Registro de riesgos
6.1.2	Evaluación de riesgos de seguridad	Parcial	5.1 / 6.4	GRC-005 / GRC-006
6.1.3	Tratamiento de riesgos de seguridad	Parcial	5.1 / 6.4 / 11	GRC-007 Plan de tratamiento / SoA
6.2	Objetivos de seguridad de la información	Sí	7. Objetivos de Seguridad de la Información	Registro de objetivos e indicadores
6.3	Planificación de cambios	Parcial	9.7 / 13	Procedimiento de gestión de cambios
7.1	Recursos	Sí	6.2 / 6.8	Planificación y asignación de recursos
7.2	Competencia	Parcial	8.5 / 9.15	Registros de formación y competencia

7.3	Concienciación	Sí	9.15 / 12	Registro de formación y concienciación
7.4	Comunicación	Sí	12. Comunicación y aceptación	Registros de comunicación
7.5	Información documentada	Sí	14. Estructura documental / 15. Control de versiones	Documentación y registros del SGSI
8.1	Planificación y control operacional	Parcial	9 / 14	Procedimientos operativos
8.2	Evaluación de riesgos	Parcial	6.4 / 13.3	Registro de riesgos
8.3	Tratamiento de riesgos	Parcial	6.4 / 11	Plan de tratamiento
9.1	Seguimiento, medición, análisis y evaluación	Sí	7.2 / 13.3	Indicadores del SGSI
9.2	Auditoría interna	Parcial	10.7 / 13.3	Programa e informes de auditoría
9.3	Revisión por la Dirección	Sí	13.6	Acta de revisión por Dirección
10.1	Mejora continua	Sí	13. Revisión y mejora continua	Registro de mejoras
10.2	No conformidad y acción correctiva	Parcial	10.8 / 13.5	Registro de acciones correctivas

B.2. Trazabilidad de los controles relevantes del Anexo A

La presente política establece directrices generales relacionadas con diferentes controles del Anexo A de ISO/IEC 27001:2022.

La correspondencia siguiente deberá utilizarse como referencia para desarrollar posteriormente la Declaración de Aplicabilidad (SoA) y la documentación específica del SGSI.

Control	Tema	Cobertura en la política	Apartado
A.5.1	Políticas para la seguridad de la información	Sí	1, 5, 6, 14 y 15
A.5.2	Roles y responsabilidades de seguridad de la información	Sí	8
A.5.3	Segregación de funciones	Sí	5.6 / 8.8
A.5.4	Responsabilidades de gestión	Sí	6 / 8
A.5.5	Contacto con autoridades	Parcial	10.1
A.5.6	Contacto con grupos de interés especial	Parcial	10.4
A.5.7	Inteligencia de amenazas	Parcial	9.6 / 13
A.5.8	Seguridad de la información en la gestión de proyectos	Parcial	9.8
A.5.9	Inventario de información y otros activos asociados	Sí	9.1
A.5.10	Uso aceptable de la información y otros activos asociados	Sí	9.18
A.5.11	Devolución de activos	Parcial	9.1 / 9.19
A.5.12	Clasificación de la información	Sí	9.2
A.5.13	Etiquetado de la información	Parcial	9.2
A.5.14	Transferencia de información	Parcial	9.2 / 9.17

A.5.15	Control de acceso	Sí	9.3
A.5.16	Gestión de identidades	Parcial	9.3 / 9.4
A.5.17	Información de autenticación	Sí	9.4
A.5.18	Derechos de acceso	Sí	9.3
A.5.19	Seguridad de la información en relaciones con proveedores	Sí	9.14
A.5.20	Seguridad en acuerdos con proveedores	Sí	9.14
A.5.21	Gestión de seguridad en la cadena de suministro TIC	Parcial	9.14
A.5.22	Monitorización, revisión y gestión de cambios de servicios de proveedores	Parcial	9.14
A.5.23	Seguridad de la información para el uso de servicios <i>cloud</i>	Parcial	9.14
A.5.24	Planificación y preparación de gestión de incidentes	Sí	9.9
A.5.25	Evaluación y decisión sobre eventos de seguridad	Sí	9.9
A.5.26	Respuesta a incidentes de seguridad	Sí	9.9
A.5.27	Aprendizaje de incidentes de seguridad	Sí	9.9 / 13
A.5.28	Recopilación de evidencias	Parcial	9.9 / 9.17
A.5.29	Seguridad de la información durante interrupciones	Sí	9.10
A.5.30	Preparación TIC para continuidad de negocio	Sí	9.10 / 9.11
A.5.31	Requisitos legales, estatutarios, reglamentarios y contractuales	Sí	10

A.5.32	Derechos de propiedad intelectual	Parcial	10
A.5.33	Protección de registros	Parcial	9.17 / 10
A.5.34	Privacidad y protección de PII	Sí	10.2 / 9.16
A.5.35	Revisión independiente de la seguridad de la información	Parcial	13
A.5.36	Cumplimiento de políticas, reglas y estándares	Sí	10.7 / 13
A.5.37	Procedimientos operativos documentados	Sí	14
A.6.1	Screening	No desarrollado	Documento específico de RR. HH.
A.6.2	Términos y condiciones de empleo	Parcial	8.5 / 12
A.6.3	Concienciación, educación y formación	Sí	9.15
A.6.4	Proceso disciplinario	No desarrollado	Política / procedimiento de RR. HH.
A.6.5	Responsabilidades después de la terminación o cambio de empleo	Parcial	8.5 / 9.3
A.6.6	Acuerdos de confidencialidad o no divulgación	Sí	9.14 / 10.3
A.6.7	Trabajo remoto	Sí	9.13
A.6.8	Notificación de eventos de seguridad	Sí	9.9
A.7.1	Perímetros de seguridad física	Parcial	9.12
A.7.2	Entrada física	Parcial	9.12

A.7.3	Seguridad de oficinas, salas e instalaciones	Parcial	9.12
A.7.4	Monitorización de seguridad física	No desarrollado	Política de Seguridad Física
A.7.5	Protección frente a amenazas físicas y ambientales	Sí	9.12
A.7.6	Trabajo en áreas seguras	Parcial	9.12
A.7.7	Escritorio y pantalla despejados	No desarrollado	Política de Uso Aceptable
A.7.8	Ubicación y protección de equipos	Parcial	9.12
A.7.9	Seguridad de activos fuera de las instalaciones	Sí	9.13
A.7.10	Medios de almacenamiento	Parcial	9.2 / 9.19
A.7.11	Servicios de soporte	Parcial	9.12
A.7.12	Seguridad del cableado	No desarrollado	Política de Seguridad Física
A.7.13	Mantenimiento de equipos	Parcial	9.5
A.7.14	Eliminación o reutilización segura de equipos	Sí	9.19
A.8.1	Dispositivos de usuario final	Sí	9.13 / 9.18
A.8.2	Derechos de acceso privilegiado	Sí	9.3
A.8.3	Restricción de acceso a la información	Sí	9.3
A.8.4	Acceso al código fuente	Parcial	9.8
A.8.5	Autenticación segura	Sí	9.3 / 9.4
A.8.6	Gestión de capacidad	No desarrollado	Procedimiento IT
A.8.7	Protección contra malware	Sí	9.5

A.8.8	Gestión de vulnerabilidades técnicas	Sí	9.6
A.8.9	Gestión de configuración	Parcial	9.5 / 9.7
A.8.10	Eliminación de información	Sí	9.19
A.8.11	Enmascaramiento de datos	No desarrollado	Política de Protección de Información
A.8.12	Prevención de fuga de datos	Parcial	9.2 / 9.3
A.8.13	Copias de seguridad	Sí	9.11
A.8.14	Redundancia de instalaciones de procesamiento	Parcial	9.10
A.8.15	Registro de eventos	Sí	9.17
A.8.16	Actividades de monitorización	Sí	9.17
A.8.17	Sincronización de relojes	No desarrollado	Procedimiento IT
A.8.18	Uso de programas utilitarios privilegiados	Parcial	9.3
A.8.19	Instalación de software en sistemas operativos	Parcial	9.5 / 9.7
A.8.20	Seguridad de redes	Sí	9.5
A.8.21	Seguridad de servicios de red	Sí	9.5
A.8.22	Segregación de redes	Parcial	9.5
A.8.23	Filtrado web	No desarrollado	Política de Uso Aceptable
A.8.24	Uso de criptografía	Parcial	9.2 / 9.5
A.8.25	Ciclo de vida de desarrollo seguro	Sí	9.8
A.8.26	Requisitos de seguridad de aplicaciones	Sí	9.8

A.8.27	Arquitectura de sistemas seguros	Parcial	9.5 / 9.8
A.8.28	Programación segura	Parcial	9.8
A.8.29	Pruebas de seguridad en desarrollo y aceptación	Parcial	9.8
A.8.30	Desarrollo externalizado	Parcial	9.8 / 9.14
A.8.31	Separación de entornos de desarrollo, pruebas y producción	Parcial	9.8
A.8.32	Gestión de cambios	Sí	9.7
A.8.33	Información de pruebas	Parcial	9.8
A.8.34	Protección de sistemas durante pruebas de auditoría	Parcial	13

B.3. Interpretación de la matriz

La matriz utiliza las siguientes categorías para representar el nivel de cobertura:

Estado	Significado
Sí	El requisito o control está contemplado expresamente en la política.
Parcial	La política establece directrices generales, pero requiere desarrollo adicional mediante procedimientos, normas o controles específicos.
No desarrollado	El requisito o control no se desarrolla en la presente política y deberá analizarse en la documentación específica del SGSI.

La clasificación "**Parcial**" no representa necesariamente una deficiencia del SGSI. La Política de Seguridad de la Información constituye un documento de alto nivel y, por tanto, determinados controles requieren documentación específica para definir su implantación y operación.

B.4. Relación con la Declaración de Aplicabilidad

La presente matriz no sustituye a la Declaración de Aplicabilidad (*Statement of Applicability, SoA*).

La SoA deberá desarrollarse posteriormente como parte de la gestión de riesgos del SGSI y deberá:

- Determinar los controles aplicables.
- Justificar la inclusión de los controles.
- Justificar la exclusión de controles cuando corresponda.
- Indicar el estado de implantación.
- Mantener la relación con los riesgos identificados.
- Mantener la trazabilidad con el tratamiento de riesgos.

La matriz de este anexo constituye una referencia inicial para facilitar el desarrollo de dicha SoA.

B.5. Revisión de la trazabilidad

La matriz deberá revisarse cuando:

- Se modifique la presente política.
- Se produzcan cambios en el alcance del SGSI.
- Se modifique el contexto de la organización.
- Se produzcan cambios significativos en los riesgos.
- Se incorporen nuevos controles.
- Se produzcan cambios relevantes en los requisitos aplicables.
- Se actualice la documentación del SGSI.

Las modificaciones deberán quedar registradas de acuerdo con el sistema de control documental establecido por PearTrees Medical Services.

ANEXO C. GLOSARIO Y DEFINICIONES

El presente glosario establece las principales definiciones utilizadas en la Política de Seguridad de la Información de PearTrees Medical Services y en la documentación relacionada con su Sistema de Gestión de Seguridad de la Información (SGSI).

Las definiciones deberán interpretarse de acuerdo con el contexto de la organización y, cuando corresponda, con la terminología establecida en las normas y marcos de referencia adoptados por el SGSI.

C.1. Activo

Elemento que tiene valor para la organización y que requiere protección frente a amenazas que puedan afectar a su confidencialidad, integridad o disponibilidad.

Los activos pueden incluir información, sistemas, aplicaciones, equipos, servicios, instalaciones, personas u otros recursos relacionados con el tratamiento de información.

C.2. Amenaza

Circunstancia, evento o actor potencial que puede aprovechar una vulnerabilidad y provocar un impacto negativo sobre un activo, proceso o servicio.

C.3. Análisis de riesgos

Proceso destinado a comprender la naturaleza del riesgo y determinar su nivel mediante la consideración de factores como la probabilidad y el impacto.

C.4. Auditoría

Proceso sistemático, independiente y documentado destinado a obtener evidencias y evaluarlas objetivamente para determinar el grado en que se cumplen determinados criterios.

C.5. Autenticación

Proceso mediante el cual se verifica la identidad declarada de una persona, sistema o entidad.

C.6. Autorización

Proceso mediante el cual se determina qué acciones, recursos o información puede utilizar o consultar una identidad previamente autenticada.

C.7. Confidencialidad

Propiedad por la que la información no se pone a disposición ni se revela a individuos, entidades o procesos no autorizados.

C.8. Control

Medida que modifica o mantiene un riesgo.

Los controles pueden ser organizativos, técnicos, físicos o de otra naturaleza y pueden tener funciones preventivas, detectivas, correctivas o de recuperación.

C.9. Disponibilidad

Propiedad de la información y de los sistemas que permite que sean accesibles y utilizables cuando sean requeridos por una entidad autorizada.

C.10. Incidente de seguridad de la información

Evento o conjunto de eventos relacionados con la seguridad de la información que puede comprometer o poner en riesgo la confidencialidad, integridad, disponibilidad o autenticidad de la información o de los servicios asociados.

C.11. Integridad

Propiedad de mantener la exactitud, completitud y consistencia de la información.

C.12. Mínimo privilegio

Principio por el cual una identidad recibe únicamente los permisos necesarios para desarrollar las funciones autorizadas.

C.13. Necesidad de conocer

Principio por el cual una persona, proceso o sistema obtiene acceso a determinada información únicamente cuando dicho acceso resulta necesario para desempeñar una función autorizada.

C.14. No conformidad

Incumplimiento de un requisito establecido.

El requisito puede proceder de una norma, legislación, regulación, contrato, política, procedimiento u otra obligación aplicable.

C.15. Parte interesada

Persona u organización que puede afectar, verse afectada o percibirse afectada por una decisión o actividad relacionada con el SGSI.

C.16. Política de Seguridad de la Información

Documento aprobado por la Dirección que establece la orientación, principios, compromisos y directrices generales de la organización respecto a la seguridad de la información.

C.17. Riesgo de seguridad de la información

Efecto de la incertidumbre sobre los objetivos relacionados con la seguridad de la información.

En el contexto del SGSI, el riesgo se analiza teniendo en cuenta escenarios que puedan afectar a la confidencialidad, integridad o disponibilidad de la información y de los servicios asociados.

C.18. Riesgo residual

Riesgo que permanece después de aplicar las medidas de tratamiento y controles establecidos.

C.19. SGSI

Sistema de Gestión de Seguridad de la Información.

Conjunto de elementos interrelacionados mediante los cuales una organización establece, implementa, mantiene y mejora la gestión de la seguridad de la información.

Incluye, entre otros elementos, políticas, procesos, responsabilidades, recursos, evaluación de riesgos, controles, seguimiento y mejora continua.

C.20. Tratamiento del riesgo

Proceso destinado a modificar un riesgo mediante acciones como evitarlo, modificarlo, compartirlo o retenerlo.

C.21. Vulnerabilidad

Debilidad de un activo, sistema, proceso o control que puede ser aprovechada por una amenaza y producir un impacto negativo.

C.22. MTTD

Mean Time to Detect — Tiempo Medio de Detección.

Indicador utilizado para medir el tiempo medio transcurrido entre la ocurrencia de un incidente y su detección por parte de la organización.

C.23. MTTR

Mean Time to Respond/Recover — Tiempo Medio de Respuesta/Recuperación.

Indicador utilizado para medir el tiempo medio necesario para responder y, según la definición adoptada por la organización, recuperar un servicio o resolver un incidente.

La organización deberá definir de forma precisa el punto inicial y final utilizado para el cálculo del indicador para garantizar resultados comparables.

C.24. Información documentada

Información que debe ser controlada y mantenida por la organización, junto con el medio que la contiene.

Puede incluir documentos, registros, evidencias, informes y otros elementos necesarios para demostrar el funcionamiento del SGSI.

C.25. Medida compensatoria

Control alternativo o adicional utilizado para reducir un riesgo cuando el control previsto no puede implantarse o no resulta suficiente.

Las medidas compensatorias deberán evaluarse en función del riesgo y mantenerse mientras resulte necesaria la excepción o circunstancia que las motivó.

C.26. Riesgo aceptable

Nivel de riesgo que la organización está dispuesta a asumir de acuerdo con sus criterios de aceptación de riesgos.

La aceptación de riesgos deberá realizarse por las autoridades correspondientes y quedar documentada cuando resulte necesario.

C.27. SGSI dentro del alcance

Conjunto de procesos, ubicaciones, personas, sistemas, servicios, información y activos incluidos dentro de los límites definidos para el Sistema de Gestión de Seguridad de la Información.

C.28. Declaración de Aplicabilidad (SoA)

Documento que identifica los controles de seguridad de la información considerados necesarios para el SGSI, proporciona la justificación de su aplicabilidad o exclusión y refleja su estado de implantación.

C.29. Evidencia

Información que permite demostrar que una actividad, control, requisito o proceso se ha realizado o se encuentra funcionando de acuerdo con los criterios establecidos.

Las evidencias pueden incluir registros, informes, configuraciones, capturas, actas, resultados de pruebas u otros elementos verificables.

C.30. Mejora continua

Actividad recurrente destinada a incrementar la adecuación, eficacia y desempeño del SGSI.

La mejora continua se apoya, entre otros elementos, en los resultados de indicadores, auditorías, incidentes, evaluaciones de riesgos, acciones correctivas y revisiones por la Dirección.